

Sistema de gestión de incidentes de seguridad informática en entornos corporativos



Universitat Oberta
de Catalunya

Miguel Perales Rubio

Grado en Ingeniería de
Tecnologías y Servicios de
Telecomunicación

Administración de redes y
sistemas operativos

Nombre Tutor/a de TF

Gonzalo Anuncibay Sánchez

**Profesor/a responsable de
la asignatura**

Montse Serra Vizern

David Bañeres Besora

Fecha Entrega

11/01/2026



Esta obra está sujeta a una licencia de
Reconocimiento-NoComercial-
SinObraDerivada [3.0 España de Creative
Commons](https://creativecommons.org/licenses/by-nc-nd/3.0/es/)

Copyright © 2025 Miguel Perales Rubio.

Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.3 or any later version published by the Free Software Foundation; with no Invariant Sections, no Front-Cover Texts, and no Back-Cover Texts.

A copy of the license is included in the section entitled "GNU Free Documentation License".

© (Miguel Perales Rubio)

Reservados todos los derechos. Está prohibido la reproducción total o parcial de esta obra por cualquier medio o procedimiento, comprendidos la impresión, la reprografía, el microfilme, el tratamiento informático o cualquier otro sistema, así como la distribución de ejemplares mediante alquiler y préstamo, sin la autorización escrita del autor o de los límites que autorice la Ley de Propiedad Intelectual.

FICHA DEL TRABAJO FINAL

Título del trabajo:	<i>Sistema de gestión de incidentes de seguridad informática en entornos corporativos.</i>
Nombre del autor:	<i>Miguel Perales Rubio</i>
Nombre del consultor/a:	<i>Gonzalo Anuncibay Sánchez</i>
Nombre del PRA:	<i>Montse Serra Vizern David Bañeres Besora</i>
Fecha de entrega:	<i>01/2026</i>
Titulación o programa:	<i>Grado en Ingeniería de Tecnologías y Servicios de Telecomunicación</i>
Área del Trabajo Final:	<i>Administración de redes y sistemas operativos</i>
Idioma del trabajo:	<i>Castellano</i>
Palabras clave	<i>Ciberseguridad, Respuesta ante incidentes, Entorno corporativo.</i>
Resumen del Trabajo	
Este Trabajo de fin de Grado - en adelante TFG - tiene como objetivo principal el diseño de un sistema de gestión de incidentes de ciberseguridad, el cual sea escalable y adaptable a diversos entornos corporativos, con independencia de su tamaño o sector. La finalidad es dotar de un marco metodológico que permita a las organizaciones tener una consistente capacidad de respuesta frente a ciberamenazas, priorizando, en todo momento, la continuidad del negocio y la mitigación de riesgos. Este trabajo está contextualizado en un entorno empresarial, el cual está caracterizado por una serie de amenazas cada vez más complejas y se basa en estándares ampliamente reconocidos como ISO/IEC 27001, ISO/IEC 27035, NIST SP 800-61r3, GDPR y el Esquema Nacional de Seguridad (ENS). En cuanto a la metodología de este trabajo, se basa en una investigación exhaustiva de las amenazas actuales, el análisis de buenas prácticas, el diseño de un ciclo de vida de incidentes y, finalmente, la definición de roles y responsabilidades. Adicionalmente, se elaborará una serie de documentación de apoyo (RACI, matrices de criticidad, plantillas de informes), y se simula un caso práctico en una empresa ficticia que sirva para validar el modelo. Finalmente, en cuanto a los resultados esperados, se incluye la definición de un procedimiento completo de la gestión ante incidentes, mediciones de KPIs y la validación del sistema mediante una simulación.	

Abstract

The main objective of this Final Degree Project is to design a cybersecurity incident management system that is scalable and adaptable to corporate environments, regardless of their size or sector. The main purpose is to provide a methodological framework that allows organisations to have a consistent response capacity to cyber threats, prioritising business continuity and risk mitigation at all times.

This work is contextualised in a business environment, which is characterised by a series of increasingly complex threats and is based on widely recognised standards such as ISO/IEC 27001, ISO/IEC 27035, NIST SP 800-61r3, GDPR and the National Security Scheme (ENS).

The methodology of this work is based on exhaustive research into current threats, analysis of best practices, design of an incident lifecycle and, finally, definition of roles and responsibilities. In addition, a series of supporting documentation (RACI, criticality matrices, report templates) will be developed, and a practical case study will be simulated in a fictitious company to validate the model.

Finally, in terms of expected results, this includes the definition of a complete incident management procedure, KPI measurements, and system validation through simulation.

Índice

1. Introducción	7
1.1. Contexto y justificación del Trabajo.....	7
1.1.1. Razón y oportunidad del proyecto	7
1.1.2. Breve introducción a la ciberseguridad	8
1.2. Objetivos del Trabajo.....	10
1.2.1. Objetivo principal	10
1.2.2. Objetivos parciales	11
1.3. Impacto en sostenibilidad, ético-social y de diversidad	12
1.3.1. La importancia de la ciberseguridad para la sostenibilidad digital	12
1.3.2. Cumplimiento GDPR	12
1.3.3. Perspectiva ética: confianza de usuarios y clientes	13
1.4. Enfoque y método seguido	14
1.5. Planificación del Trabajo.....	15
1.5.1. Diagrama de Gantt	15
1.5.2. Cronograma del proyecto	15
1.6. Breve resumen de productos obtenidos	19
1.7. Breve descripción de los otros capítulos de la memoria	20
2. Materiales y métodos.....	21
2.1. Normativas y estándares.....	21
2.2. Documentación y guías	24
2.3. Antecedentes y situación actual.....	26
2.3.1. Evolución histórica de la seguridad informática	26
2.3.2. Contexto actual.....	29
2.4. Bases conceptuales de la ciberseguridad.....	30
2.5. Principales amenazas	31
2.5.1. Ataques a contraseñas	32
2.5.2. Ataques mediante ingeniería social	33

2.5.3.	Ataques a las conexiones	34
2.5.4.	Ataques mediante el empleo de <i>malware</i>	37
2.6.	Ciclo de vida de un incidente.....	39
2.6.1.	Preparación	39
2.6.2.	Identificación.....	41
2.6.3.	Contención	42
2.6.4.	Mitigación	43
2.6.5.	Recuperación	45
2.6.6.	Post-Incidente.....	45
2.7.	Gobernanza y marcos de la ciberseguridad	45
2.7.1.	Roles principales	46
2.8.	Metodología utilizada en la simulación del caso práctico.....	47
2.8.1	Conceptos previos.....	47
2.8.2	Descripción de la empresa	48
2.8.3	Análisis de impacto en el negocio BIA.....	52
2.8.4	Simulación de incidentes	53
2.8.5	Metodología de la simulación	54
3.	Resultados.....	55
3.1.	Visión general de los resultados obtenidos	55
3.2.	Documentación de apoyo	55
3.3.	Caso práctico	57
3.3.1.	Contexto y escenario previo del incidente.....	57
3.3.2.	Detección y registro del incidente	58
3.3.3.	Clasificación y evaluación del incidente	61
3.3.4.	Gestión del incidente	62
3.3.5.	Cierre del incidente.....	64
3.3.6.	Incidentes de apoyo para la validación del sistema	66
3.4.	Indicadores clave	68
3.4.1.	MTTD	68
3.4.2.	MTTR	69
3.4.3.	Tasa de falsos positivos.....	70

3.5. Análisis de resultados	70
4. Conclusiones y trabajos futuros	74
4.1. Conclusiones	74
4.2. Líneas de trabajo futuras y propuestas de mejora	75
5. Glosario.....	77
6. Bibliografía	84
7. Anexos	87
Anexo A: Registro y gestión de incidentes.....	87
Anexo B: Clasificación y criticidad de incidentes.....	89
Anexo C: Roles y responsabilidades (Matriz RACI).	90
Anexo D: Procedimientos operativos de respuesta.....	91
Anexo E: Plantillas de informes y KPIs.....	94

Lista de figuras

Figura 1: Evolución de la seguridad en la empresa.....	8
Figura 2. Incidentes de ciberseguridad en sectores clave en 2024.....	10
Figura 3. Gráfico de incidentes más frecuentes en 2024.	10
Figura 4. Diagrama de Gantt de la PEC1.....	16
Figura 5. Diagrama de Gantt de la PEC 2.....	17
Figura 6. Diagrama de Gantt de la PEC 3.....	18
Figura 7. Diagrama de Gantt de la finalización del TFG.....	19
Figura 8. Propagación geográfica de <i>Code Red</i>	29
Figura 9. Triada CIA.	30
Figura 10. Tácticas, Técnicas y Procedimientos (TTP).....	32
Figura 11. Fases de la gestión de una crisis.	39
Figura 12. Madurez de ciberseguridad de la empresa	51
Figura 13. Niveles de peligrosidad del ciberincidente	56
Figura 14. Niveles de impacto de un ciberincidente	56

Lista de tablas

Tabla 1. Objetivos parciales y tareas asociadas.	11
Tabla 2. Fases del sistema de gestión de incidentes.	14
Tabla 3. Planificación PEC 1.....	16
Tabla 4. Planificación PEC 2.....	17
Tabla 5. Planificación PEC 3.....	18
Tabla 6. Planificación final del TFG.....	19
Tabla 7. Fuente de análisis de posibles incidentes.	42
Tabla 8. Acciones de contención inmediatas.	42
Tabla 9. Medidas fase de mitigación	44
Tabla 10. Roles y responsabilidades.....	47
Tabla 11. Análisis BIA	52
Tabla 12. Incidentes simulados en el caso práctico	54
Tabla 13. Cronología del incidente 1: <i>Ransomware</i>	58
Tabla 14. Registro de incidente.....	60
Tabla 15. Clasificación y criticidad del incidente	62
Tabla 16. Protocolo de comunicación de crisis.	64
Tabla 17. Informe post-incidente	66
Tabla 18. Cronología del incidente 2.....	67
Tabla 19. Cronología del incidente 3.....	68
Tabla 20. Tasa de falsos positivos.	70
Tabla 21. Objetivos parciales conseguidos.	75

1. Introducción

1.1. Contexto y justificación del Trabajo

En este Trabajo de Fin de Grado se pretende proporcionar un marco detallado y estructurado para hacer frente tanto a la prevención como a la gestión de incidentes de seguridad informática.

La dependencia tecnológica de las organizaciones está aumentando de forma exponencial y, del mismo modo, la exposición de sus activos a incidentes de ciberseguridad. En la actualidad, los ataques son cada vez más sofisticados, afectando a empresas de cualquier ámbito o tamaño. Por tanto, se pone de manifiesto la necesidad de disponer de una serie de mecanismos eficaces que sirvan para prevenir, detectar, responder y finalmente, recuperar la actividad con el mínimo impacto posible.

Por otra parte, muchas organizaciones carecen de procedimientos estandarizados adaptados a su realidad, lo que dificulta, en gran medida, una respuesta eficiente. Mediante estos procedimientos se debe garantizar la disponibilidad, la integridad y/o la confidencialidad de los activos de la organización.

Es en este escenario donde surge la motivación para este Trabajo de Fin de Grado, el cual propone el desarrollo de un modelo integral de gestión de incidentes combinando una serie de buenas prácticas con un enfoque práctico y adaptable.

1.1.1. Razón y oportunidad del proyecto

La ciberseguridad se ha convertido en un factor estratégico muy influyente en lo que respecta a la continuidad del negocio, la confianza de los clientes y el cumplimiento normativo. De este modo, invertir recursos en ciberseguridad no solo responde a una necesidad técnica, sino también a una decisión empresarial clave para asegurar la competitividad y la resiliencia frente a los riesgos del entorno digital.

Es en este contexto donde surge la oportunidad de este TFG, debido a la necesidad recurrente de un modelo claro y documentado que oriente a las organizaciones en todo lo relativo a la gestión de incidentes de ciberseguridad.

En la actualidad, la gestión de incidentes de seguridad informática ha sufrido una evolución de forma paralela al incremento de las amenazas.

Si bien existen marcos normativos ampliamente consolidados -como, por ejemplo, ISO/IEC 27035 o NIST SP 800-61 - su implementación práctica, especialmente en pequeñas empresas, supone un gran esfuerzo de interpretación y adaptación a un ámbito que, normalmente, es muy diferente al modelo de negocio.

Por tanto, la motivación de este proyecto radica en ofrecer una serie de propuestas metodológicas que simplifiquen al máximo la implementación de un proceso de

gestión de amenazas e incidentes, aportando una serie de herramientas de apoyo - plantillas, matrices, diagramas, etc.- para, finalmente, demostrar su utilidad en un caso práctico, estando siempre alineado con la creciente demanda de resiliencia digital y, además, con el cumplimiento normativo en materia de seguridad informática.

1.1.2. Breve introducción a la ciberseguridad

En primer lugar, definimos la seguridad informática como *“todas las tecnologías, prácticas y políticas para prevenir los ciberataques o mitigar su impacto. La ciberseguridad tiene como objetivo proteger los sistemas informáticos, las aplicaciones, los dispositivos, los datos, los activos financieros y las personas contra el ransomware y otros malware, las estafas de phishing, el robo de datos y otras ciberamenazas.”* [1]

En lo relativo al ámbito que nos ocupa, la ciberseguridad en el mundo empresarial se puede entender como un conjunto coordinado de medidas tecnológicas, de organización y humanas orientadas a la protección de los activos digitales de la empresa frente a amenazas que puedan comprometer la operatividad. No está únicamente limitado a la utilización de herramientas defensivas, conlleva establecer una serie de políticas y una cultura corporativa orientada, en todo momento, a la protección de la información.

Pese a que la ciberseguridad es un concepto relativamente moderno - surgido a mediados del siglo pasado -, ha experimentado una serie de variaciones hasta llegar a ser el conjunto de herramientas y de estrategias que utilizamos en la actualidad.

La seguridad informática tiene sus comienzos en un embrionario internet, en la década de los 60 del siglo XX. Anteriormente la única manera de acceder de forma fraudulenta a un equipo era físicamente.

En 1969, ARPA fue capaz de enviar un mensaje desde un ordenador de la Universidad de California en Los Ángeles a través del estado hasta un dispositivo del Instituto de Investigación de Stanford. Había nacido, por tanto, el ciberespacio. [2]



Figura 1: Evolución de la seguridad en la empresa.
Fuente: INCIBE

En la década de los 70, el grueso de la población era ajeno a la seguridad en la información y, por tanto, el ámbito corporativo no era una excepción.

Los años 80 trajeron los primeros virus informáticos y, en contrapartida, los primeros antivirus.

En los 90, internet comenzó a hacerse popular y una gran cantidad de hogares y de empresas quedaron expuestos en la red. Fue una década en la que, principalmente la falta de formación al respecto supuso un auge en fraudes y ataques.

En el siglo XXI, la sociedad en general cambió su forma de utilizar la red con la irrupción de las redes sociales. En el ámbito corporativo se empezó a ser consciente de la magnitud del problema, adoptando una serie de herramientas como firewalls y sistemas de detección de intrusos. Además, se hizo patente la necesidad de adoptar unas pautas y criterios ante estas amenazas, surgiendo así las primeras normativas de seguridad. [3]

A partir del año 2010, con el auge de los dispositivos móviles, las personas comienzan a estar conectadas en cualquier situación, aumentando la exposición y el riesgo ante amenazas.

Y así llegamos al contexto actual, donde, en un reciente balance de ciberseguridad presentado por INCIBE, se muestra un escenario marcado por la intensificación y sofisticación de las amenazas. Durante el pasado año, en España se han registrado más de 97.000 incidentes de ciberseguridad, una cifra que evidencia la creciente presión sobre la infraestructura digital nacional y en consecuencia la necesidad imperiosa de reforzar las medidas de protección.

En el mismo informe, se muestra una tendencia hacia unos métodos mucho más dirigidos y dañinos. Una de las mayores preocupaciones para las empresas continúa siendo el *ransomware*, donde los ciberdelincuentes buscan, además del cifrado de datos, la extorsión.

Por otra parte, los fraudes online han experimentado un alarmante crecimiento, utilizando técnicas de *phishing* y de suplantación de identidad cada vez más convincentes y difíciles de detectar. Los ciberdelincuentes aprovechan contextos de crisis y eventos de actualidad para lanzar campañas masivas que pueden llegar a confundir incluso a usuarios experimentados.



Figura 2. Incidentes de ciberseguridad en sectores clave en 2024.
Fuente: INCIBE

Pese a que los ciudadanos particulares concentran un número mayor de incidentes, las pequeñas y medianas empresas se enfrentan a amenazas particularmente graves debido a sus limitaciones en cuanto a los recursos dedicados a ciberseguridad. El sector público y las infraestructuras críticas también reciben atención constante por parte de actores maliciosos llegando incluso a correr el riesgo de poner en jaque al país. [4]

A continuación, en base a este informe, en la Figura 3, se muestra una gráfica con los incidentes de seguridad informática más frecuentes el año pasado en España:

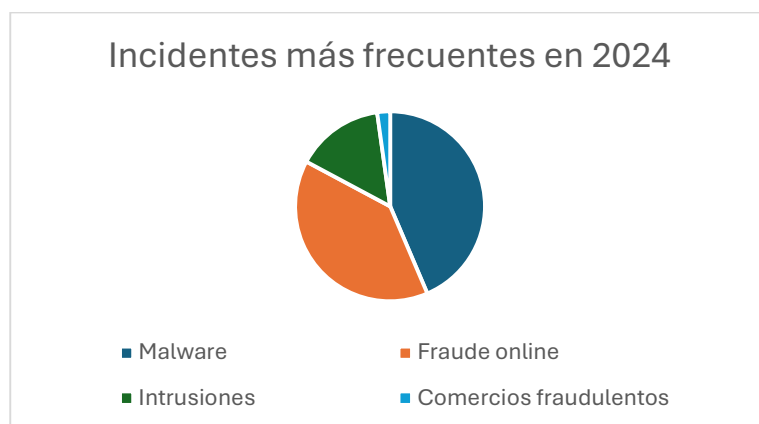


Figura 3. Gráfico de incidentes más frecuentes en 2024.
Fuente: INCIBE

1.2. Objetivos del Trabajo

1.2.1. Objetivo principal

El objetivo principal de este TFG es el diseño de un sistema de gestión de incidentes de seguridad informática, el cual cumpla con los siguientes objetivos:

En primer lugar, debe estar, en todo momento, en concordancia con los estándares reconocidos.

Los roles de todos los agentes implicados - externos e internos - deben quedar perfectamente definidos, así como sus responsabilidades y los procedimientos a llevar a cabo ante incidentes.

Otro de los objetivos principales es dar prioridad, en todo momento, a la continuidad del negocio y la mitigación de riesgos.

Además, se deben proporcionar una serie de plantillas y documentación de apoyo para cada una de las fases del ciclo de vida de un incidente.

Finalmente, se debe validar el modelo mediante la simulación de un caso práctico en una empresa ficticia, evaluando tiempos de detección, contención y recuperación.

1.2.2. Objetivos parciales

Los objetivos parciales de este TFG y sus tareas asociadas se muestran - de forma gráfica - en la siguiente tabla:

Objetivo parcial	Tarea asociada
Investigación de las amenazas	Documentar las principales amenazas en el contexto actual.
Análisis preliminar	Revisión de normativa y recopilación de buenas prácticas.
Diseño metodológico	Evaluar el ciclo de vida de incidentes y definir roles.
Elaboración de documentación	RACI, matrices de criticidad, diagramas de flujo, informes, etc.
Simulación práctica	A modo de ejemplo: aplicación del modelo en un caso ficticio.
Medición de indicadores	Evaluación con KPIs: MTTR, MTBD y tasa de falsos positivos

Tabla 1. Objetivos parciales y tareas asociadas.

Por otra parte, quedan fuera del alcance de este TFG:

- Implementar soluciones técnicas en lo relativo a herramientas de seguridad, como pueden ser: SIEM, IDS/IPS, EDR, SOAR u otras.

- Configuración de sistemas para la detección o mitigación de incidentes de ciberseguridad, como, por ejemplo: servidores, redes, cortafuegos, etc.
- Pruebas de intrusión o escenarios de ataques reales.
- La utilización de datos reales de individuos o empresas; el TFG, por tanto, se limitará únicamente a un entorno ficticio.

1.3. Impacto en sostenibilidad, ético-social y de diversidad

La ciberseguridad, como disciplina esencial en el ámbito tecnológico y empresarial, además de la incidencia que supone en los aspectos técnicos y de prestigio de la empresa, tiene un impacto en lo relativo a la ética, lo social y la sostenibilidad.

En todo momento - al desarrollar este TFG - se ha procurado dotarlo con un enfoque responsable que considere la protección de la información como un elemento primordial para la sostenibilidad digital, el cumplimiento normativo y la confianza de los usuarios.

Por otra parte, se hace énfasis en la importancia del respeto a la diversidad y a los derechos fundamentales de todos los actores implicados en los procesos relacionados con la gestión de incidentes.

1.3.1. La importancia de la ciberseguridad para la sostenibilidad digital

Mediante la sostenibilidad digital, se garantiza que los sistemas tecnológicos, los datos - especialmente los sensibles - y los servicios digitales puedan desarrollar su actividad y mantenerse seguros, fiables y éticos a lo largo del tiempo.

Concretamente, desde la perspectiva empresarial, la ciberseguridad constituye un pilar fundamental, ya que protege los activos digitales y, además, evita interrupciones que puedan comprometer la continuidad de negocio, el bienestar de los usuarios o la estabilidad económica de una organización.

Mediante el empleo de procedimientos claros para la gestión, prevención, detección, respuesta y recuperación ante incidentes de seguridad, el modelo propuesto en este Trabajo Final de Grado contribuye, en todo momento, a la sostenibilidad digital. Este enfoque permite minimizar el impacto económico asociado a fallos críticos y/o pérdidas de información, al mismo tiempo que promueve un uso más eficiente y responsable de los recursos tecnológicos.

Además de los aspectos técnicos, se pone de manifiesto la necesidad de considerar la sostenibilidad social, es decir, la protección de las personas frente a vulneraciones de privacidad, fraudes o daños reputacionales derivados de un ciberataque.

1.3.2. Cumplimiento GDPR

El Reglamento General de Protección de Datos, en castellano, - en adelante RGPD - va mucho más allá de un marco normativo aplicable. El fomento de prácticas

empresariales basadas en la transparencia, el consentimiento informado y la minimización del riesgo suponen una gran herramienta para la sostenibilidad y equidad digital.

Tanto desde una perspectiva ética como legal, el cumplimiento del GPRD representa un compromiso para cualquier organización que gestione datos de carácter personal. En este TFG se ha empleado, en todo momento, como un eje regulador esencial para la gestión de incidentes, con el fin de garantizar que las acciones de respuesta respeten los derechos fundamentales de las personas involucradas y la confidencialidad de los datos.

Este reglamento pone el foco en aspectos tan relevantes como el derecho de acceso -los individuos pueden preguntar qué datos se procesan-, el derecho al olvido -solicitud de borrado -, y la portabilidad - transferir datos de un controlador a otro -. Estos derechos, además de proteger la privacidad, fomentan la transparencia y la confianza entre las organizaciones y los usuarios para, de esta forma, consolidar la ética y la responsabilidad en lo que respecta al tratamiento de la información digital. [5]

1.3.3. Perspectiva ética: confianza de usuarios y clientes

La seguridad informática, además de una disciplina técnica fundamental, supone un compromiso ético de cualquier corporación con la protección de la información y, por tanto, un pilar esencial para preservar la confianza.

En el contexto que nos ocupa - el mundo empresarial - la gestión responsable de los datos personales y corporativos refleja el respeto hacia los derechos de las personas y el cumplimiento de una serie de valores fundamentales como son la transparencia, la integridad y la confidencialidad. Estos principios éticos son claves para fortalecer la confianza de los clientes, quienes depositan en las organizaciones la custodia de su información más sensible.

Una actitud proactiva en cuanto a la seguridad de la información conlleva algo tan importante como la confianza digital. Esta solamente se logra aplicando políticas claras de protección de datos, comunicación transparente ante incidentes y mecanismos eficaces de respuesta.

Desde esta perspectiva, la ética en la seguridad informática va más allá de evitar el daño, consiste en anticiparse, en la medida de lo posible, a él, adoptando una serie de medidas que garanticen la disponibilidad y el uso legítimo de la información.

Además, actuar de forma ética en este ámbito conlleva reconocer las implicaciones tanto humanas como sociales de cada decisión técnica que se adopte, equilibrando, en todo momento, la eficiencia operativa con el respeto por la privacidad y la dignidad de las personas.

Es, por tanto, indispensable para este proyecto ir más allá de un simple marco para la mejora de procesos técnicos, promoviendo una cultura organizativa basada en la

responsabilidad y la ética digital, reforzando el vínculo entre tecnología y valores, consolidando un entorno empresarial que sea mucho más seguro, más transparente y sostenible.

1.4. Enfoque y método seguido

La metodología que se seguirá en la elaboración de este Trabajo de Final de Grado se enfoca, principalmente, en un profundo análisis y una estructuración de la gestión de incidentes de ciberseguridad. Para su realización podemos diferenciar claramente tres fases:

En la primera parte del TFG se abordarán una serie de conceptos teóricos y las normativas necesarias para enfrentarnos a los ciberincidentes.

Seguidamente, en la segunda parte, se desarrollará de forma estructurada un sistema de gestión de incidentes, el cual se puede definir en tres fases: prevención, gestión de ciberincidentes y recuperación. Cada una de ellas cumple con un rol específico dentro del ciclo de vida de un incidente de ciberseguridad.

	Prevención	Gestión	Recuperación
Definición	Esta fase consiste en la anticipación y la reducción de la probabilidad de que el incidente ocurra.	En esta fase se detectan, analizan y gestionan los incidentes de seguridad. El objetivo es la contención, minimizar los daños y restaurar la normalidad.	El objetivo de esta fase es restablecer la normalidad operativa y fortalecer el sistema tras el incidente.
Acciones	- Identificación y evaluación de activos críticos. - Análisis de riesgos y vulnerabilidades. - Buenas prácticas de los empleados y usuarios de los sistemas.	- Detección y notificación del incidente. - Clasificación del incidente y asignación de prioridad - Análisis de las causas. - Contención y mitigación - Comunicación del incidente, tanto de forma interna como externa.	- Informe post incidente. - Revisión y, si fuera necesario, actualización de políticas corporativas. - Mediante indicadores de rendimiento medir la eficacia del sistema ante la amenaza
Enfoque general	Fase más importante y base del modelo	Requiere coordinación entre los equipos técnicos, la dirección y los responsables de comunicación	Cierre del incidente y mejora del sistema

Tabla 2. Fases del sistema de gestión de incidentes.

Para finalizar, se realizará la simulación de un caso práctico en una empresa ficticia poniendo en práctica la metodología desarrollada en la fase anterior.

La estrategia escogida se considera adecuada para alcanzar los objetivos propuestos, ya que integra un enfoque preventivo, reactivo, y de mejora continua y se alinea con el marco de buenas prácticas en materia de ciberseguridad y gestión.

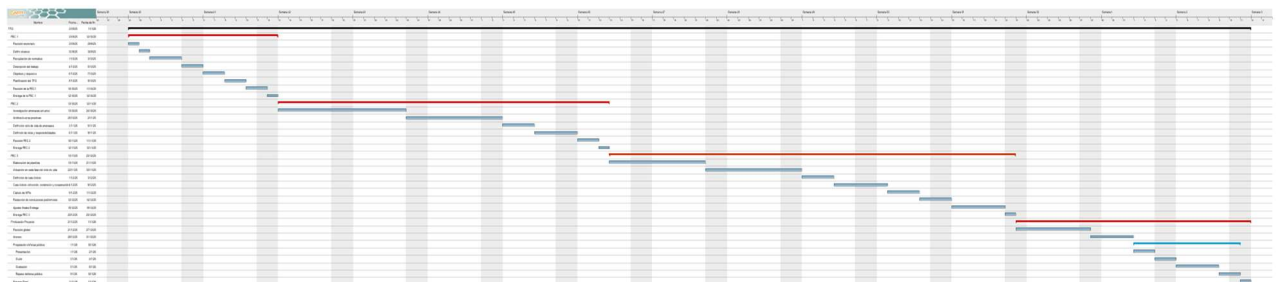
La división en tres partes del modelo - prevención, gestión y recuperación - permite abordar de una forma estructurada el conjunto del ciclo de vida del incidente.

Finalmente, cabe destacar que el método seguido combina elementos teóricos con la simulación de un caso práctico, lo que facilita, en gran medida, su aplicabilidad en entornos empresariales.

1.5. Planificación del Trabajo

1.5.1. Diagrama de Gantt

A continuación, se muestra el diagrama de Gantt completo de toda la planificación del TFG. En la sección “anexos” se adjunta para una visualización más detallada. En el apartado 1.5.2 se detalla la planificación de este Trabajo de Fin de Grado.



1.5.2. Cronograma del proyecto

Planificación en función de los entregables de la asignatura:

En primer lugar -y a modo de explicación de la cronología de este TFG- vamos a enumerar los aspectos clave y la planificación temporal en función de cada una de las entregas.

Fechas clave:

- Entrega PEC 1 → 12 de octubre de 2025.
- Entrega PEC 2 → 16 de noviembre de 2025
- Entrega PEC 3 → 21 de diciembre de 2025
- Entrega Final → 11 de enero de 2026
- Defensa pública → 29 de enero de 2026

A continuación, vamos a desglosar cada uno de los hitos relevantes para cada una de las entregas con una breve descripción:

PEC 1:

Planificación semanal	Tarea	Días de trabajo
Semana I	Revisión del enunciado	1
	Definición de alcance	1
	Recopilación de normativa	3
	Descripción del trabajo	2
Semana II	Objetivos y requisitos	2
	Planificación del TFG	2
	Revisión PEC 1	2
	Entrega PEC 1	1

Tabla 3. Planificación PEC 1.

Diagrama de Gantt de la PEC 1:

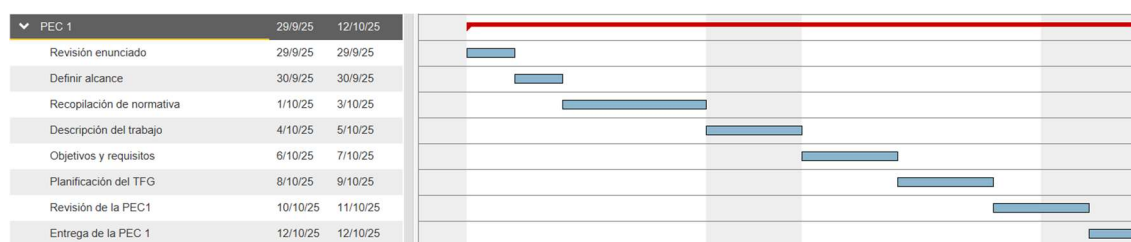


Figura 4. Diagrama de Gantt de la PEC1.
Realizado con GanttProject

PEC 2

Planificación semanal	Tarea	Días de trabajo
Semana III	Investigación de amenazas en el contexto actual	12
Semana IV		
Semana V	Análisis de buenas practicas	9
Semana VI	Definición ciclo de vida de amenazas	3
	Definición de roles y responsabilidades	4
Semana VII	Revisión PEC 2	2
	Entrega PEC 2	2

Tabla 4. Planificación PEC 2.

Diagrama de Gantt de la PEC 2:

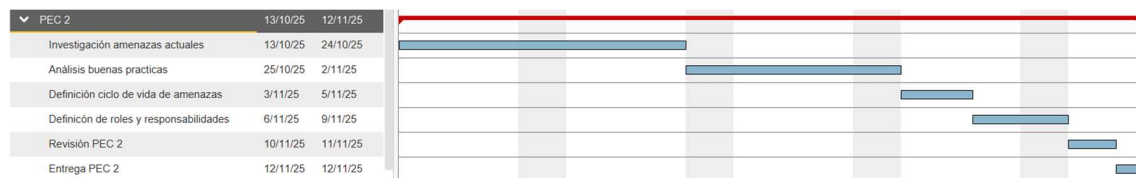


Figura 5. Diagrama de Gantt de la PEC 2.
Realizado con GanttProject

PEC 3:

Planificación semanal	Tarea	Días de trabajo
Semana VII	Elaboración de plantillas	9
Semana VIII		
Semana IX	Actuación en cada fase del ciclo de vida	9
Semana X	Definición de caso ficticio	3
	Caso ficticio: detección, contención y recuperación	5
Semana XI	Cálculo de KPIs	3
	Redacción de conclusiones preliminares	3
Semana XII	Ajustes finales de la entrega	5
	Entrega PEC 3	1

Tabla 5. Planificación PEC 3.

Diagrama de Gantt de la PEC 3:

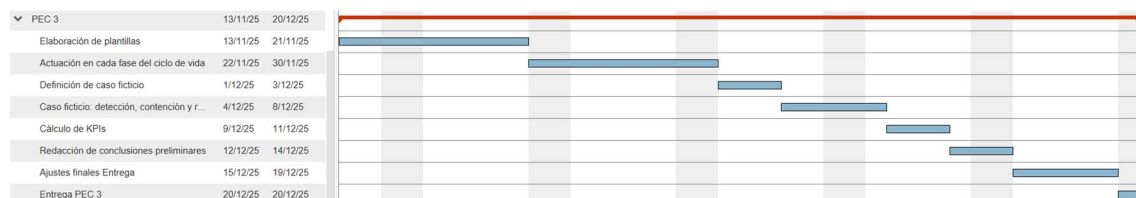


Figura 6. Diagrama de Gantt de la PEC 3.
Realizado con GanttProject

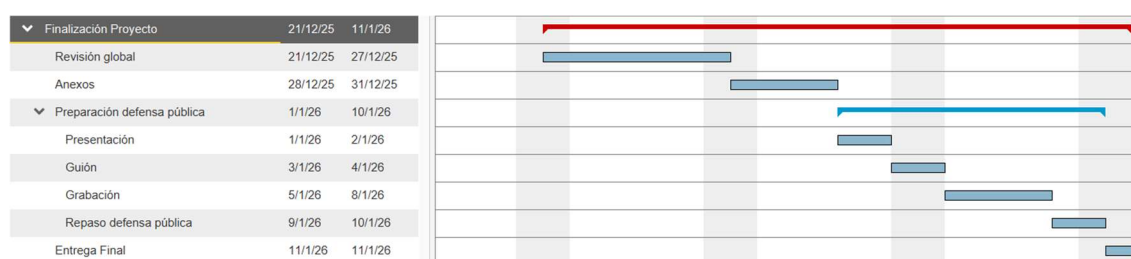
Finalización y preparación de la defensa pública:

Una vez concluidas las entregas de cada una de las PECs, comenzaremos a preparar la defensa pública y a realizar las últimas revisiones y correcciones sobre la memoria del proyecto, es decir, comienza la fase de finalización del TFG:

	Tarea	Días de trabajo
Semana XII	Revisión global	7
Semana XIII	Anexos	3
Semana XIV	Presentación	2
Semana XIV	Guión	2
Semana XV	Grabación	4
Semana XV	Repaso defensa pública	2
Semana XV	Entrega final	1

Tabla 6. Planificación final del TFG.

Diagrama de Gantt de la fase final del Trabajo:



**Figura 7. Diagrama de Gantt de la finalización del TFG.
Realizado con GanttProject**

1.6. Breve resumen de productos obtenidos

Los principales productos obtenidos en este TFG son:

- Un modelo de gestión de incidentes alineado con ISO/IEC 27035 y NIST SP 800-61.
- Un conjunto de plantillas y documentos operativos -registro de incidentes, matriz RACI, procedimientos de respuesta, informes post-incidentes – los

cuales faciliten la implementación del modelo y sirvan de referencia para llevar a cabo la implementación en un caso práctico.

- Un caso práctico de simulación aplicado al sector sanitario, con un análisis detallado de tres tipos de incidentes y cálculo de indicadores clave (KPIs) para la evaluación del sistema propuesto.

1.7. Breve descripción de los otros capítulos de la memoria

A continuación, en el Capítulo 2 de esta memoria, se desarrolla el marco teórico y normativo que servirá de base para el resto de los apartados. Este marco proporciona la base conceptual y regulatoria sobre la que se apoya el modelo propuesto. Se abordarán los conceptos fundamentales relacionados con la seguridad informática, los modelos de gestión de incidentes y la legislación aplicable.

En el Capítulo 3, se realizará una presentación de los principales resultados que se han obtenido a lo largo del TFG, detallando el modelo de gestión de incidentes diseñado junto con una serie de documentación de apoyo - plantillas, diagramas y matrices de criticidad - las cuales facilitarán su aplicación práctica. Asimismo, se incluye el desarrollo de un caso práctico en un entorno empresarial ficticio, para, de esta manera validar la eficacia del modelo y los indicadores de rendimiento asociados.

Finalmente, en el Capítulo 4, se incluyen las conclusiones generales y se muestra el análisis de los resultados obtenidos en la simulación. Se evaluará la viabilidad de la aplicación de este modelo junto con su adaptabilidad a escenarios diversos y su eficiencia. Además, se establecen una serie de recomendaciones para la implementación del modelo en organizaciones reales.

2. Materiales y métodos

2.1. Normativas y estándares

Pese a que no son las únicas existentes, a continuación, desglosaremos algunas de las normativas y estándares internacionales más relevantes:

ISO/IEC 27000

Serie de normas que nacieron en 1995 bajo la denominación de BS 7799, son desarrolladas por la Organización Internacional de Normalización (ISO) y por la Comisión Electrotécnica Internacional (IEC), y está formada por un conjunto de 45 normas. Cabe destacar que se actualizan cada 5 años, siendo la última actualización en 2022 [6]. A continuación, nombraremos las más relevantes para el objetivo de este TFG:

- **La ISO/IEC 27000** aporta, por tanto, una visión general sobre los sistemas de seguridad en la información, además incorpora una serie de términos y definiciones que son de uso generalizado en el resto de los estándares de la misma familia.
- **ISO/IEC 27001- Sistemas de Gestión de Seguridad de la Información**, en este estándar se hace una exposición de los requisitos para realizar un Sistema de Gestión de la Seguridad de la Información. Su propósito es garantizar, en todo momento, la confidencialidad, integridad y disponibilidad de la información utilizando un enfoque basado en riesgos. Define un marco organizativo que abarca políticas, procedimientos, responsabilidades y controles de seguridad, a modo de síntesis podemos destacar los siguientes:
 - Debe estar claramente documentado.
 - Debe estar preparado y capacitado para adelantarse y mitigar cualquier tipo de riesgo.
 - Los recursos que destine la organización deben ser suficientes para cumplir con su cometido.
 - Finalmente, debe ser revisado y actualizado de forma regular.
- **ISO/IEC 27002- Controles de seguridad de la información**, complemento de la anterior, hace una descripción mucho más detallada de cada uno de los controles necesarios. Sirve como una especie de guía de buenas prácticas para seleccionar, implementar y gestionar medidas de seguridad específicas. Está estructurada por dominios: control de accesos, seguridad física, gestión de activos o continuidad de negocio, y nos ofrece recomendaciones prácticas para cada uno de ellos.
- **ISO/IEC 27003-Guía de implementación de SGSI**, proporciona una orientación general sobre la construcción de un Sistema de Gestión de la Seguridad de la Información. Nos ofrece orientación para establecer el alcance

del sistema, definir la política de seguridad, analizar riesgos, planificar objetivos y gestionar recursos.

- **ISO/IEC 27004- Medición de la eficacia del SGSI**, establece las directrices necesarias para medir, evaluar y mejorar la eficacia de un SGSI. Propone una serie de métricas e indicadores cuantitativos que permiten determinar si los controles y procesos implementados cumplen con los objetivos de seguridad previstos.
- **ISO/IEC 27005-Gestión del riesgo de seguridad de la información** es un compendio de códigos de prácticas dedicado a la gestión de riesgos en la seguridad de la información que definen una metodología para identificar, analizar, evaluar y tratar los riesgos que amenazan la seguridad de la información. Entre sus secciones, podemos destacar:
 - La evolución previa de los riesgos
 - La decisión sobre si cada uno de los riesgos deben ser mitigados, aceptados o evitados
 - La monitorización de cada uno de ellos riesgos.
- **ISO/IEC 27033-Seguridad de redes y comunicaciones**, en esta normativa se desarrollan los códigos de prácticas necesarios para la seguridad en la red interna de una empresa. Proporciona una serie de principios, técnicas y buenas prácticas para diseñar e implementar infraestructuras de red seguras, protegiendo, en todo momento, la información que circula a través de ellas.
- **ISO/IEC 27035- Gestión de incidentes de seguridad de la información**, la normativa más relevante para este sistema de incidentes de seguridad, en ella se detalla todo lo relativo a la gestión de incidentes de seguridad de la información y el plan de respuesta ante incidentes. Define, de forma clara, las fases de preparación, detección, análisis, respuesta y aprendizaje posterior al incidente, promoviendo un enfoque sistemático que permita minimizar el impacto y restaurar la operatividad a la mayor brevedad posible.
- **ISO/IEC 27701- Extensión para la gestión de la privacidad (PIMS)** estándar de reciente creación el cual cubre todo lo relativo al RGPD de la Unión Europea. Define las responsabilidades tanto para responsables como para encargados del tratamiento, y proporciona un marco de referencia para el cumplimiento y transparencia en cuestión de privacidad y protección de datos.

NIST SP 800-61

El *National Institute of Standards and Technology* (NIST), es una agencia norteamericana fundada en 1901 cuyo objetivo principal es promover la innovación y la competitividad industrial mediante el desarrollo de estándares, mediciones y tecnologías que garanticen la calidad, la seguridad y la interoperabilidad en distintos sectores.

En el ámbito de la seguridad informática, se trata de una de las instituciones con más reconocimiento en todo el planeta, ha elaborado una serie de marcos de referencia, guías y publicaciones que establecen buenas prácticas y estándares internacionales para la gestión de riesgos, protección de sistemas de información y respuesta a incidentes.

Concretamente, el estándar NIST SP 800-61, el cual actualmente va por su tercera revisión, tiene como objetivo principal unificar una serie de recomendaciones y consideraciones en lo relativo a la respuesta a incidentes de ciberseguridad para las organizaciones. Está basada en el *Cybersecurity Framework* (CSF) 2.0. Sirve para que las corporaciones puedan tener una mejor preparación y reducir la cantidad y el impacto de los incidentes. [7]

RGPD (Reglamento General de Protección de Datos)

El Reglamento General de Protección de Datos - que entró en vigor el 25 de mayo de 2018 - es la piedra angular de la reforma de la protección de datos en la UE. Parte de la premisa principal de garantizar la protección de las personas físicas en lo relativo al tratamiento de sus datos personales, tanto por parte del sector privado como del sector público. [8]

Se trata, por tanto, de una normativa integral, la cual equilibra la protección de los derechos fundamentales de los individuos con la necesidad de permitir el flujo de datos y la innovación empresarial en el mercado único digital de la UE, estableciendo obligaciones claras y concisas para las organizaciones y derechos reforzados para los ciudadanos.

El RGPD garantiza una serie de derechos para las personas:

- Derecho de acceso.
- Derecho a la portabilidad de los datos.
- Derecho al olvido.
- Derecho a ser informado ante una violación de sus datos.

En lo relativo al objetivo de este TFG, cabe destacar la figura del Delegado de Protección de Datos (DPO) ya que, con la entrada en vigor de este reglamento, las empresas cuyo tratamiento de datos sea a gran escala o se dediquen a categorías especiales de datos tienen la obligación de designar a tal efecto la figura de un responsable de la protección de datos.

Esquema Nacional de Seguridad (ENS)

El ENS nos marca una base normativa para definir la política de seguridad de la información que deben seguir todas las administraciones públicas y sus colaboradores privados en España para proteger sus sistemas, datos y servicios digitales. Dicho esquema viene regulado por el Real Decreto 311/2022, de 3 de mayo. [9]

2.2. Documentación y guías

En este apartado se hace referencia a las guías elaboradas por el Instituto Nacional de Ciberseguridad (INCIBE), las cuales constituyen una fuente de información esencial en materia de ciberseguridad a nivel nacional. A través de estos documentos - y aunque en ciertos aspectos puedan resultar redundantes - se cubre un amplio abanico de situaciones a las que se enfrenta cualquier tipo de organización, desde grandes corporaciones hasta pequeñas y medianas empresas o profesionales autónomos.

En conjunto, estas guías y documentaciones conforman un ecosistema documental coherente y complementario, orientado a la creación de una cultura sólida de ciberseguridad de gran utilidad para el tejido empresarial en nuestro país.

Estas herramientas no solo sirven como referencia técnica, sino también como instrumentos estratégicos que permiten a las organizaciones anticiparse a las amenazas, reducir riesgos y establecer una serie de protocolos estandarizados de actuación ante incidentes de seguridad informática.

Más concretamente, en el contexto de este Trabajo Final de Grado, su aplicación práctica y teórica proporciona el sustento necesario para comprender y diseñar políticas de ciberseguridad eficaces y siempre alineadas con recomendaciones prácticas nacionales y europeas.

Por tanto, estas guías se emplearán como referencia tanto en el desarrollo de este apartado del Trabajo Final de Grado como en la simulación del caso práctico, sirviendo como marco normativo y metodológico para la prevención, detección y gestión de incidentes de ciberseguridad. Su valor radica en que ofrecen pautas prácticas, recomendaciones técnicas y procedimientos normalizados que refuerzan la resiliencia digital de las entidades en un contexto geopolítico inestable que nos lleva a un entorno cada vez más expuesto a las amenazas cibernéticas.

Ciberamenazas contra entornos empresariales (INCIBE)

Se trata de un documento mediante el cual INCIBE nos proporciona una guía práctica para hacer frente a las principales ciberamenazas que afectan tanto a empresas como a autónomos. Su objetivo principal es concienciar y proporcionar conocimientos que resultan esenciales para identificar, prevenir y responder de forma eficaz a incidentes de ciberseguridad. [10]

Su estructura está basada en tres pilares fundamentales:

- La ingeniería social como base de los ataques.
- Principales amenazas desglosadas
- Decálogo de recomendaciones de seguridad.

Guía de ciberseguridad en la identidad digital (INCIBE)

Esta guía ofrece un marco integral para gestionar proactivamente una serie de desafíos, proporcionando recomendaciones prácticas de ciberseguridad que permiten a las organizaciones proteger su imagen digital, mantener la confianza de sus clientes y garantizar la continuidad del negocio en un contexto constantemente evolutivo. [11]

Se estructura en una serie de secciones clave para desarrollar estos objetivos:

- Identidad digital
- Reputación en la red.
- Riesgos relativos a la gestión de la identidad digital y la reputación online.
- Marco legal aplicable.
- Recomendaciones para la gestión de la identidad digital.

Guía Para la Gestión de fugas de información (INCIBE)

Un aspecto fundamental, como es la fuga de información, constituye una de las mayores amenazas para las empresas en el contexto actual, un contexto en el cual la información confidencial se ha convertido en un activo crítico y, a la vez, en un objetivo para los ciberdelincuentes. Esta guía nos proporciona un marco integral para la gestión de estos incidentes, abordando desde la prevención mediante medidas técnicas, organizativas y legales, hasta la respuesta estructurada ante una filtración, con el objetivo de minimizar el impacto en la reputación, evitar consecuencias legales y económicas, y restaurar la confianza de clientes y socios. [12]

Guía de Gestión de Crisis (INCIBE)

Esta guía establece un marco integral para todo lo relativo a la gestión proactiva de crisis de ciberseguridad, abordando aspectos que van desde la preparación y prevención mediante planes de continuidad y simulacros, hasta la respuesta coordinada, comunicación transparente con *stakeholders* y las lecciones aprendidas, con el objetivo de fortalecer la resiliencia de la organización y garantizar la rápida recuperación ante incidentes críticos.

Después de indicarnos conceptos sobre el organismo que realiza estas guías, y de una introducción, nos desglosa tres aspectos clave: la definición de crisis de seguridad, una serie de buenas prácticas para, en caso de que ocurra, gestionar la crisis y finalmente, un aspecto que se suele dejar de lado, la gestión de crisis ocasionadas en la cadena de suministro, es decir, de otros agentes relacionados con la actividad empresarial como, por ejemplo, los proveedores. [13]

Guía Nacional para la Notificación y Gestión de Ciberincidentes (INCIBE)

Esta Guía Nacional para la Notificación y Gestión de Ciberincidentes, la cual fue aprobada por el Consejo Nacional de Ciberseguridad en el mes de febrero de 2020, tiene como objetivo estandarizar y armonizar los procedimientos de notificación y gestión de incidentes de ciberseguridad.

Mediante un esquema claro y muy preciso, en el documento se establecen los criterios de clasificación, los niveles de peligrosidad e impacto del ciberincidente, los canales de notificación oficiales a través de una ventanilla única coordinada por todos los CSIRT de referencia en España (CCN-CERT, INCIBE-CERT y ESP-DEF-CERT), los plazos y la información requerida para las comunicaciones obligatorias. [14]

Guía para la Gestión de Ciberincidentes en el Sector Privado (INCIBE-CERT)

En combinación con la Guía Nacional para la Notificación y Gestión de Ciberincidentes - tratada en el párrafo anterior -, es de gran utilidad este Procedimiento de Gestión de Ciberincidentes para el Sector Privado y la Ciudadanía de INCIBE-CERT, que desarrolla operativamente todas las fases del ciclo de vida de un incidente, es decir, preparación, identificación, contención, mitigación, recuperación y lecciones aprendidas, junto con los procedimientos específicos de actuación para dicho ámbito.

Juntas, estas guías proporcionan un marco integral y práctico que sirve para analizar la respuesta a incidentes en España, desde la clasificación y notificación inicial hasta la resolución y mejora continua, constituyendo la base normativa y metodológica sobre la que se sustenta esta investigación. [15]

Guía de Ciberataques OSI (INCIBE OSI)

En la Guía de Ciberataques que nos proporciona OSI encontramos la base tanto técnica como divulgativa, detallando la taxonomía de amenazas - desde ataques por ingeniería social y *malware* hasta intrusiones en conexiones - y las medidas de protección necesarias para el usuario final. [16]

2.3. Antecedentes y situación actual

2.3.1. Evolución histórica de la seguridad informática

En primer lugar, cabe destacar que la evolución de la seguridad informática en términos generales y, concretamente, en entornos corporativos ha seguido una trayectoria a lo largo del tiempo paralela al desarrollo tecnológico. Si bien ya se planteó un pequeño esbozo de esta evolución en apartados anteriores de este TFG, a continuación, se realizará un análisis más extenso desde los inicios de la informática hasta la era actual.

En las últimas décadas, la protección digital ha experimentado una transformación radical. desde sus inicios, las estrategias de defensa han evolucionado en consonancia con la intensidad con la que se han ido sofisticando las tácticas ofensivas. Este viaje cronológico abarca desde un primitivo gusano Morris hasta las cada vez más sofisticadas amenazas contemporáneas, reflejando una carrera constante entre la innovación tecnológica y la protección de la información.

Primeros pasos:

En un primer momento, el matemático húngaro John von Neumann - a mediados del siglo XX – en la *Theory of Self-reproducing Automata* [17] estableció por primera vez la idea de que un programa informático puede contener instrucciones para hacer copias de sí mismo y sentó las bases teóricas que predijeron y explicaron el comportamiento del *malware* autorreplicante. Sentó las bases para la creación de virus y gusanos informáticos al demostrar que el código malicioso podía propagarse entre sistemas por sí solo sin ayuda humana.

En el ámbito empresarial, durante las décadas de 1960 y 1970, la protección se centraba principalmente en el acceso físico, donde las medidas de seguridad consistían en controles de acceso a las salas de computación y sistemas de almacenamiento físico, haciendo énfasis en la protección contra el robo físico de información y/o el sabotaje. Junto a esto la seguridad informática era un concepto incipiente que se limitaba a contraseñas básicas y una serie de permisos rudimentarios.

Años 80: el virus informático Brain y el gusano Morris:

La década de 1980 marcó un antes y un después en la ciberseguridad, sirve como punto de inflexión debido a la aparición de las dos primeras amenazas mundiales: *Brain*, el primer virus para PC, y *Morris*, el primer *malware* con impacto global. Ambos episodios transformaron la percepción de la ciberseguridad, pasando de ser un problema técnico marginal a una cuestión estratégica de gran importancia.

En primer lugar, hablaremos del virus informático *Brain*, el cual fue creado por dos hermanos pakistaníes, *Basit y Amjad Farooq Alvi*, *Brain* infectaba los sistemas IBM compatibles a través de disquetes. Su funcionamiento estaba basado en modificar el sector de arranque de los discos para ejecutar código malicioso al iniciar el sistema. Aunque su intención nunca fue destructiva, ya que mostraba solo un mensaje con información de los autores, demostró por primera vez cómo el *software* podía autorreplicarse entre dispositivos sin ningún tipo de consentimiento por parte del usuario, exponiendo así la vulnerabilidad de los sistemas personales [18].

Por otra parte, *Morris*, fue desarrollado por Robert Tappan Morris, este gusano explotaba vulnerabilidades en sistemas Unix conectados a ARPANET – la predecesora de Internet -. Un error en su código causó que se replicara de forma descontrolada, infectando aproximadamente un 10% de la red que había en ese momento, llegando a colapsar servicios críticos [19]. Sus consecuencias fueron trascendentales para el futuro de la seguridad informática:

- Conllevó asociada a su aparición la creación del primer equipo de respuesta ante incidentes.
- Motivó la creación de leyes a tal efecto como la *Computer Fraud and Abuse Act* en los Estados Unidos.

- Puso en evidencia la vulnerabilidad de las redes globales y, por tanto, demostró que requerían protocolos de seguridad informática robustos.

Los años 90 del siglo pasado: la era de internet:

Fue en esta década en la que se aceleró la proliferación de forma generalizada de internet, tanto en el ámbito empresarial como en el doméstico. Por tanto, el ciberespacio dejó de ser un dominio de empresas tecnológicas, ámbitos académicos y ejércitos. La creación de la *World Wide Web* por Tim Berners-Lee en 1991, combinada con el lanzamiento de navegadores accesibles e intuitivos como Mosaic (1993) y posteriormente el popular Internet Explorer (1995), eliminó las barreras técnicas que limitaban el acceso a la red al público general. Esta explosión en la conectividad supuso una gran cantidad de nuevos vectores de ataque y desafíos de seguridad sin precedentes.

Emergieron nuevas formas de *malware* mucho más complejas, como, por ejemplo, los macro virus que se propagaban a través de documentos de *Office*, y aparecieron las primeras *botnets* organizadas. Además, los ataques DDoS comenzaron a perfeccionarse, con la popularización del correo electrónico el *phishing* encontró un vector ideal para engañar a usuarios novatos. Por tanto, una creciente dependencia de sistemas conectados transformó unos incidentes que antes eran únicamente locales en problemas con un gran potencial, capaces de afectar a millones de personas simultáneamente.

Es en este contexto, donde comienzan a aparecer los primeros *firewalls* comerciales pensado para entornos domésticos y protocolos como SSL comenzaron a implementarse para proteger transacciones financieras online.

El nuevo siglo: de la guerra fría a la guerra cibernética.

Con el fin de la guerra fría y el nuevo contexto internacional, en la década del año 2000 comenzó la profesionalización global de la seguridad informática. Esta década estuvo marcada por la aparición de gusanos devastadores: como *ILOVEYOU* – el cual infectó a alrededor de cincuenta millones de ordenadores - y *Code Red* los cuales pusieron en evidencia, una vez más, la vulnerabilidad de las redes interconectadas.

ILOVEYOU surgió el 4 de mayo de 2000 en forma de un mensaje de correo electrónico el cual tenía como asunto “*ILOVEYOU*” y contenía un archivo adjunto - *LOVE-LETTER-FOR-YOU.TXT.vbs* – una vez abierto, no solo infectaba el equipo, sino que se autopropagaba a todas las direcciones de la agenda del usuario.

Por otra parte, *Code Red* [20], fue un gusano informático que explotó una vulnerabilidad crítica en servidores web Microsoft IIS mediante un desbordamiento de búfer en la extensión “.ida”. En la figura 8 se muestra la propagación geográfica del gusano en intervalos de cinco minutos entre la

medianoche UTC del 19 de julio de 2001 y la medianoche UTC del 20 de julio de 2001.

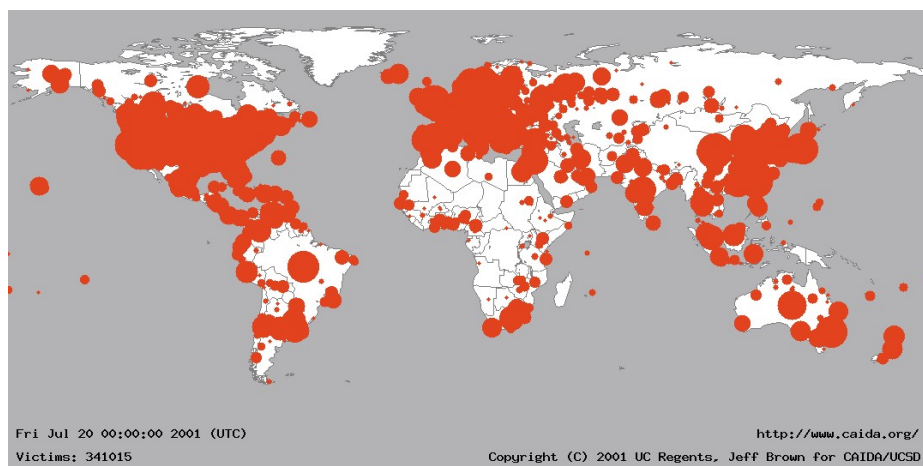


Figura 8. Propagación geográfica de Code Red.
Fuente: Caida

Ambos gusanos marcaron un punto de inflexión en el concepto de la concienciación sobre seguridad informática, quedando patente que una sola vulnerabilidad podía comprometer globalmente, con todo lo que esto supone, infraestructuras críticas en cuestión de horas. Su análisis supuso una considerable mejora en los sistemas de detección temprana y una respuesta coordinada ante incidentes.

Es en este contexto donde aparece un concepto relativamente nuevo, el cibercrimen organizado con *botnets* comerciales y mercados *darknet*, mientras que, por otra parte, las empresas transformaban la seguridad de una función técnica reactiva a un riesgo estratégico, adoptando estándares como ISO 27001 y posiciones ejecutivas dedicadas (CISO).

La década de los 2000 sentó las bases de la ciberseguridad y, además, nos dejaron un aprendizaje crucial: la protección reactiva basada en firmas y parches resultó claramente insuficiente. Con una creciente sofisticación del cibercrimen organizado anticipaban una nueva era donde la seguridad requeriría enfoques mucho más proactivos, cooperación internacional y una integración más profunda entre tecnología, negocios y sociedad. Este escenario prepararía el terreno para los desafíos de la próxima década: la irrupción del teléfono móvil, la nube y la inteligencia artificial como nuevos frentes de batalla.

2.3.2. Contexto actual

Y así llegamos al contexto actual, a partir de 2020 asistimos a una transformación sin precedentes la cual fue impulsada por la hiperconectividad *5G/IoT*, la computación cuántica, la inteligencia artificial y la migración masiva a entornos *cloud* e híbridos. Por tanto, estamos ante el momento más avanzado tecnológicamente de la historia.

Iniciamos un periodo marcado por ciberamenazas con un impacto físico mucho más directo - hospitales, infraestructuras críticas - y, de forma paralela, la superficie de ataque se expandió de forma exponencial con 30,000 millones de dispositivos IoT en 2025.

Los ciberdelincuentes han demostrado una notable adaptación a las nuevas medidas de seguridad implementadas, siempre un paso por delante. Ataques como, por ejemplo, los de *ransomware* a gran escala o las brechas masivas de datos han dejado en evidencia la vulnerabilidad de las empresas incluso de las corporaciones más avanzadas tecnológicamente.

Tal y como muestra *Telefónica Tech* en su informe sobre el primer semestre de 2025 [21] estamos ante un panorama de amenazas en lo relativo a la seguridad informática recientemente sofisticado y globalizado.

2.4. Bases conceptuales de la ciberseguridad

La seguridad de la información es una preocupación fundamental para cualquier tipo de organización en un mundo cada vez más interconectado. En esta sección, así como en las siguientes, intentaremos ofrecer una visión general de los principios generales de la ciberseguridad, ya que conocer las ideas básicas de la seguridad informática nos permite prevenir los peligros.

La tríada CIA (confidencialidad, integridad y disponibilidad) es la piedra angular sobre la que debe construirse todo plan de ciberseguridad [22].



Figura 9. Tríada CIA.
Fuente: Fortinet

Mediante la Confidencialidad se garantiza que la información sea accesible únicamente para aquellos usuarios autorizados y con este objetivo se implementan técnicas de cifrado, controles de acceso y políticas de privilegios mínimos.

Por otra parte, la Integridad asegura que los datos no sean alterados de forma no autorizada, para lograr esto se emplean mecanismos como hashes criptográficos y firmas digitales.

La Disponibilidad garantiza por que los sistemas y datos sean accesibles cuando siempre que sean necesarios, implementando redundancias, backups y planes de recuperación ante desastres.

Cabe destacar que la mayor amenaza siempre es el factor humano y, por tanto, la concienciación es un componente crucial.

Por tanto, la ciberseguridad moderna requiere un enfoque holístico el cual combine tecnología, procesos y personas, adaptándose continuamente a un panorama de amenazas en constante evolución.

2.5. Principales amenazas

En primer lugar, en el contexto de la seguridad informática en el entorno empresarial, las amenazas pueden definirse como cualquier situación que, aunque no se haya producido, tenga una serie de efectos perjudiciales para las operaciones, la marca corporativa, las funciones de la empresa o la reputación y/o imagen de esta [23].

En un mundo está cada vez más conectado digitalmente y con un entorno geopolítico mundial extremadamente inestable, resulta necesario reconocer y clasificar estos peligros con el objetivo de poder contrarrestarlos.

En ese sentido, la Agencia de la Unión Europea para la Ciberseguridad (ENISA) realiza su informe anual *Threat Landscape* [24] el cual nos ofrece una imagen clara de los principales peligros a los que nos enfrentamos. Para elaborar el informe de 2025, los expertos de ENISA han recopilado y examinado 4875 incidentes, utilizando principalmente los datos proporcionados, de forma anónima, por miembros del Programa de Colaboración Cibernética de la ENISA e información extraída de fuentes abiertas.

En este informe afirma que los cinco sectores más afectados y los principales objetivos de los ciberdelincuentes son las administraciones públicas, el transporte, las infraestructuras y servicios digitales, la banca y la industria. Más de la mitad de todos los incidentes se atribuyen a entidades consideradas esenciales.

En cuanto a las tácticas utilizadas, el *phishing* representó alrededor del 60 % de los casos de intrusión, lo que lo convierte en el método más común. Los correos electrónicos y los anuncios maliciosos además de las visitas a sitios web falsos entran dentro de esta categoría.

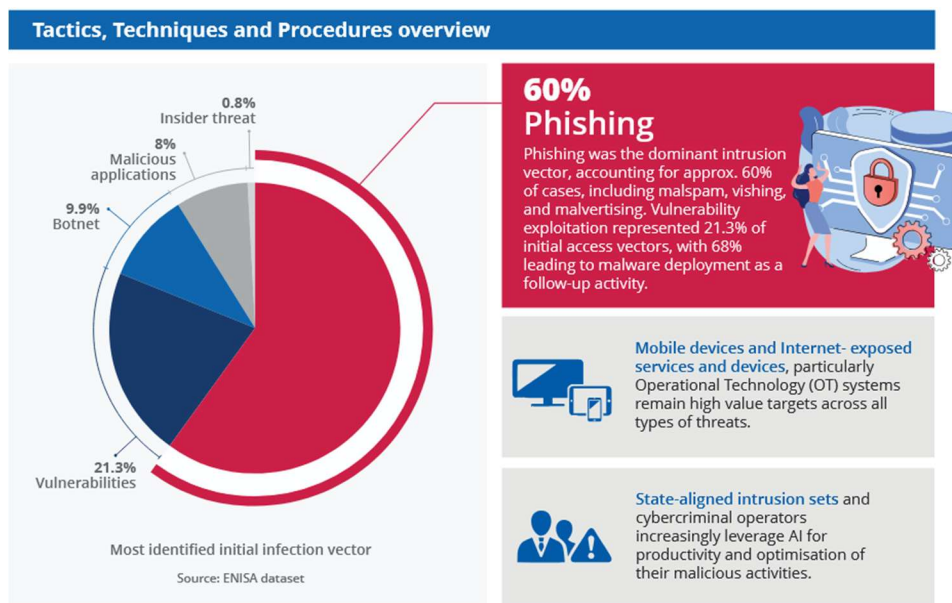


Figura 10. Tácticas, Técnicas y Procedimientos (TTP).

Fuente: EINSIA

Podemos llegar a la conclusión – según este informe - de que las previsiones para 2025 muestran un cambio. El campo de batalla sigue estando definido por amenazas como el *ransomware*, el *phishing* y el *hacktivismo*, pero estas se están volviendo cada vez más eficaces. El uso de inteligencia artificial por parte de los atacantes marca el inicio de una nueva era en la que las campañas pueden llegar a ser considerablemente más generalizadas, personalizadas y, lo que es más importante, muy difíciles de identificar, lo que requiere mejoras continuas en las capacidades de defensa y resiliencia de las organizaciones.

De forma más concisa, a continuación, haremos un desglose de los ciberataques más frecuentes a los que nos enfrentamos:

A modo de referencia – para documentar los ciberataques - se ha empleado la información existente en la Guía de Ciberataques (OSI) [16].

2.5.1. Ataques a contraseñas

Existen herramientas y técnicas muy diversas con las que los ciberdelincuentes pueden atacar nuestras credenciales, los más destacados son:

- **Fuerza bruta:** los ataques de fuerza bruta consisten en intentar adivinar las credenciales de un usuario mediante la técnica de ensayo y error, con nuestros datos personales – en caso de conocerlos – o introduciendo combinaciones de palabras al azar - nombres, letras, números, etc. – hasta llegar a encontrar la combinación adecuada.

Con este objetivo, los ciberdelincuentes se sirven de herramientas como *Hydra* o *Medusa*, las cuales pueden llegar a probar miles de combinaciones por minuto.

- **Ataque por diccionario:** este tipo de ataques tienen como objetivo intentar descifrar nuestras contraseñas de acceso utilizando combinaciones de letras con la ayuda de algoritmos automatizados.

Por lo general, estos ataques utilizan listas predefinidas las cuales contienen las contraseñas más comunes, entradas de diccionarios en varios idiomas y algunas de sus variaciones incluso con sustitución de algunos caracteres. Cuando se combinan con la información personal del objetivo obtenida, por ejemplo, mediante ingeniería social, su eficacia aumenta considerablemente.

2.5.2. Ataques mediante ingeniería social

- **Phishing, Vishing, Smishing:** estos tres tipos de ataques de ingeniería social se llevan a cabo de una manera muy similar. Utilizan un mensaje que se hace pasar por una organización de nuestra confianza, como bancos, servicios de entrega o servicios técnicos. Las aplicaciones de mensajería instantánea, las redes sociales y el correo electrónico se utilizan en el *phishing*. Las llamadas telefónicas se utilizan en el *vishing*. Por último, los estafadores utilizan mensajes SMS para el *smishing*.

Estos ataques se han vuelto cada vez más complejos y han evolucionado hasta convertirse en lo que conocemos como *spear phishing*, el cual se caracteriza por mensajes extremadamente personalizados para cada objetivo.

- **Baiting o gancho:** en este tipo de ataques se suele utilizar un medio físico, como un supuesto premio o un USB infectado y, lo que es más importante, la curiosidad humana e incluso la codicia. Los atacantes utilizan esta trampa para engañarnos y que compartamos información personal o infectemos nuestros propios sistemas.

Su principal objetivo es engañar a los usuarios para que conecten dispositivos comprometidos en su equipo o entren en anuncios atractivos que nos prometen un supuesto premio. De esta forma el *malware* puede tomar el control del ordenador, robar nuestra información personal, infectar la red y propagarse a otros dispositivos.

Como cebos más comunes podemos encontrar: USB ubicados en lugares estratégicos – como aparcamientos –, descargas de *software* pirata, encuestas con premios, etc.

- **Shoulder surfing:** o la técnica de “mirar por encima del hombro”, en la que los *hackers* se colocan cerca de los usuarios de un ordenador o una red y controlan sigilosamente sus movimientos con el fin de recopilar información. Al igual que

los anteriores ataques de ingeniería social, el objetivo principal de este tipo de ataques es el robo de información, y suelen producirse en lugares públicos como cafeterías, aeropuertos o cajeros automáticos.

En el contexto actual, son muchas las empresas que utilizan el teletrabajo como medio de conciliación profesional y familiar, y, por tanto, este riesgo se ha incrementado de forma exponencial.

- ***Dumpster Diving***: el clásico “buscar en la basura” en ocasiones no somos conscientes de que tanto los documentos, las notas manuscritas como otros dispositivos que tiramos a la basura en el lugar de trabajo pueden contener información importante. En los deshechos que generamos, en ocasiones, también se pueden llegar a encontrar discos duros y equipos obsoletos, lo que podría suponer un grave problema si los datos no se han borrado por completo.
- ***Spam***: su funcionamiento consiste en bombardear a los usuarios con una gran cantidad de publicidad no solicitada, con contenido comercial o promocional, en ocasiones pueden incluir algún tipo de *malware*.
- ***Fraudes online***: mediante la ingeniería social se pueden llevar a cabo todo tipo de fraudes y/o estafas online con las que engañar a los usuarios para conseguir una serie de datos personales, o, incluso, con el objetivo de obtener un beneficio económico.

En múltiples ocasiones los ciberdelincuentes se aprovechan de eventos o emergencias con el objetivo de crear una urgencia de forma artificial.

2.5.3. Ataques a las conexiones

Las redes son un vector de ataque comúnmente utilizado por los ciberdelincuentes, cuyo objetivo principal es comprometer los protocolos de seguridad empleando herramientas especializadas. Los ataques de tipo *man in the middle*, por ejemplo, son intrusiones las cuales pretenden interceptar la transmisión de datos entre los usuarios y los servicios de Internet.

El objetivo principal de estos ataques es obtener datos confidenciales, como información financiera, información personal y contraseñas de inicio de sesión.

- ***Redes trampa***: con el objetivo de engañar a los usuarios de la red, se crea una red *Wi-Fi* idéntica a otra red fiable y segura, con un nombre igual o muy similar al original. Este tipo de ataques se producen con frecuencia en lugares con redes inalámbricas públicas.

Una vez establecida la conexión, los atacantes pueden interceptar todas las comunicaciones de la víctima, incluida la información bancaria, los mensajes y las contraseñas.

- **Spoofing:** es una técnica de ciberataque que consiste en la suplantación de identidad, donde un atacante falsifica información para hacerse pasar por una entidad, dispositivo o usuario legítimo.

El objetivo principal es el engaño a sistemas o a personas para conseguir un acceso no autorizado, el robo de información, o redirigir el tráfico. Esta técnica resulta especialmente peligrosa porque socava la confianza en los sistemas de autenticación básicos.

- **IP Spoofing:** el objetivo de los ciberdelincuentes es el de hacer pasar su IP por otra diferente y así se consigue ocultar el origen de un ataque.

Este método se utiliza frecuentemente en combinación con ataques DDoS - los cuales veremos más adelante -, para llegar a saturar un servidor con tráfico aparentemente legítimo desde múltiples fuentes falsificadas.

- **Web Spoofing:** consiste en la imitación de una página web real con el objetivo de suplantarla, es decir, de hacernos creer que la página creada a tal efecto es la real.

Este tipo de páginas pueden llegar a resultar casi idénticas a las originales y legítimas, llegando incluso a replicar logos, diseños, tipografía, etc., siendo realmente complicada su identificación.

- **Email Spoofing:** se trata de un tipo de robo de identidad por correo electrónico el cual consiste en que el atacante falsifica la dirección del remitente para que el mensaje parezca provenir de una fuente fiable. Las campañas de phishing y los ataques BEC (*Business Email Compromise*) lo emplean con frecuencia.
- **DNS Spoofing:** con el objetivo de redirigir el tráfico legítimo a servidores maliciosos se alteran los registros DNS. Actualmente, se trata de uno de los métodos más sofisticados y peligrosos. La manipulación deliberada de los registros DNS - Sistema de Nombres de Dominio - es la base de este tipo de ataque. La particularidad de este método es su transparencia para el usuario, el cual es redirigido inadvertidamente a una copia falsificada del sitio web original cuando introduce una URL legítima en su navegador. Estas copias, que tienen exactamente el mismo aspecto que los portales auténticos, se crean expresamente para robar datos confidenciales, como información bancaria o contraseñas de inicio de sesión.

Ataques a Cookies: las cookies son pequeños ficheros que contienen información de páginas web que hemos visitado con anterioridad con el objetivo de que la navegación sea más fluida, evitando tener que procesar la información cada vez que se accede a una página frecuente. Los ataques a Cookies representan una gran amenaza a la seguridad en la web, ya que explotan estos archivos con el objetivo de suplantar identidades y acceder de forma ilegítima a cuentas de usuario. Resultan particularmente peligrosos los

ataques a cookies que almacenan información tan relevante como tokens de autenticación, credenciales de acceso o información personal sensible.

- **Ataque DDoS:** se trata de ataques distribuidos de denegación de servicio, y su funcionamiento es un ataque múltiple y simultáneo a un servidor web con el objetivo de anularlo.

En la actualidad, representan una de las amenazas más disruptivas en el panorama de la seguridad informática, caracterizándose por la coordinación de múltiples sistemas comprometidos - frecuentemente organizados en botnets - los cuales saturan simultáneamente un servidor, servicio y/o infraestructura de red. Esta sobrecarga deliberada puede terminar agotando los recursos del sistema - ancho de banda, capacidad de procesamiento o memoria, etc. - hasta llegar a su colapso total, impidiendo, de esta forma, que los usuarios legítimos accedan a los servicios. Lo particularmente crítico de estos ataques radica en su naturaleza distribuida, que dificulta enormemente la identificación y bloqueo de las fuentes originales.

- **Inyección SQL:** este tipo de ataque permite a los ciberdelincuentes insertar líneas de código SQL – lenguaje de programación de bases de datos - maliciosas en el propio aplicativo web, con el objetivo de obtener un acceso parcial o completo a los datos, incluso de ser monitorizados, modificados o robados por el atacante.

Con este propósito, los ciberdelincuentes emplean técnicas como la inyección basada en *UNION* para extraer datos de múltiples tablas, consultas ciegas - blind SQLi - para inferir información mediante respuestas condicionales, o inyecciones temporales que utilizan retardos en la ejecución con el objetivo de mapear la estructura de la base de datos. Las consecuencias de estos ataques pueden resultar devastadoras, incluyendo, por ejemplo, el robo masivo de información confidencial como pueden ser: credenciales de usuario, datos personales, o información financiera.

Cabe destacar que, en los casos más graves, los atacantes pueden lograr la escalada de privilegios, la manipulación o destrucción de datos, e incluso llegar a tomar control completo del sistema subyacente mediante la ejecución de comandos del sistema operativo.

- **Escaneo de puertos:** el escaneo de puertos, o *portscan*, es el proceso en el cual se analizan de forma automática los puertos de un equipo conectado a la red. Estos escaneos se realizan con la finalidad de analizar los puertos e identificar cuáles están abiertos, cerrados o cuentan con algún protocolo de seguridad. Para estos escaneos se emplean herramientas como *Nmap*, *Zmap* o *Masscan*.
- **Man in the middle:** en este caso, el atacante se posiciona entre dos partes que creen estar comunicándose directamente sin ser detectado. Con este tipo de ataque se pretende la explotación de vulnerabilidades en protocolos de

comunicación los cuales no sean cifrados o estén deficientemente autenticados, permitiendo al intruso interceptar, modificar o incluso inyectar tráfico en tiempo real sin llegar a ser detectado. Una vez más, los escenarios de riesgo son particularmente elevados en redes wifi públicas no seguras.

- **Sniffing:** constituye una práctica de monitorización encubierta que permite la interceptación pasiva de las comunicaciones dentro de una red. En este caso, los atacantes hacen uso de herramientas especializadas conocidas como *sniffers* o analizadores de protocolos.

El objetivo de este tipo de ataques es el de capturar, almacenar y analizar el tráfico de datos que circula a través de una red. Esta técnica opera explotando fundamentalmente la naturaleza *broadcast* de las redes *Ethernet* y *Wi-Fi*, donde los paquetes de datos son teóricamente accesibles para los dispositivos conectados al mismo segmento de la red.

Cabe destacar que la efectividad de este método reside en su capacidad para operar de forma silenciosa y no intrusiva, realizando un análisis meticuloso de los protocolos de comunicación como HTTP, FTP o SMTP los cuales transmiten la información en texto claro por defecto.

2.5.4. Ataques mediante el empleo de *malware*

Finalmente, enumeraremos los vectores de ataque más peligrosos de una de las amenazas más persistentes y evolutivas del panorama actual: los ataques mediante el empleo de *malware*.

En términos generales, son códigos maliciosos que han sido diseñados con el objetivo de infiltrarse, dañar o tomar el control de sistemas y dispositivos, adoptan formas diversas como, por ejemplo, virus, gusanos, troyanos, *ransomware* o *spyware*. A continuación, haremos un desglose en función del *modus operandi* y de la forma de infección:

- **Virus informáticos:** se trata de códigos maliciosos que tienen como objetivo realizar copias de sí mismos y propagarse a la mayor cantidad posible de dispositivos. Además, suelen contener cargas dañinas – *payloads* - diseñadas para alterar el funcionamiento de los sistemas, corromper archivos o robar información.
- **Adware:** es un tipo de *software* malicioso que tiene como objetivo la propagación de anuncios no deseados. En ocasiones integran técnicas de rastreo de comportamiento (*tracking*) para recopilar datos de navegación, búsquedas e intereses del usuario, que luego son vendidos a terceros.
- **Spyware:** se trata de un *malware* que se instala en los equipos y comienza a recopilar información, supervisando toda la actividad del usuario para posteriormente compartirlo con un usuario remoto. Posee, además, la

capacidad de descargar e instalar de forma autónoma otros códigos maliciosos en el sistema comprometido.

- **Troyanos:** es un tipo de *malware* que suele estar camuflado como un *software* legítimo con el objetivo de infectar nuestro equipo. Su objetivo es controlar el dispositivo de la víctima, robar los datos, introducir más *software* malicioso en el equipo y propagarse a otros dispositivos.
- **Backdoors:** se trata de mecanismos de acceso oculto que permiten eludir los procesos de autenticación convencionales, facilitando la entrada remota no autorizada a sistemas o aplicaciones. A diferencia de otras amenazas, su peligrosidad radica en la persistencia y el sigilo, ya que incluso suelen diseñarse para permanecer activos tras actualizaciones o reinicios del sistema.
- **Keyloggers:** los *Keyloggers* operan como programas espía capturan y almacenan de forma encubierta todas las entradas realizadas mediante el teclado, sin autorización del usuario.
- **Stealers:** son un tipo de troyano capaz de acceder a la información almacenada en el equipo. Una vez ejecutado, analiza los programas instalados y las credenciales almacenadas para luego, compartirlas con el atacante.
- **Ransomware:** con este *malware* se pretende tomar el control del dispositivo para cifrar el acceso al mismo y/o nuestros archivos o discos duros. Para recuperar el control y el acceso a la información, los ciberdelincuentes suelen exigir un rescate.
- **Gusano:** son un tipo de programas maliciosos autónomos diseñados para replicarse de forma automática y masiva a través de redes, sin necesitar ningún tipo de intervención del usuario. A diferencia de los virus, no necesitan adjuntarse a archivos legítimos para propagarse, lo que les permite infectar sistemas a gran velocidad.
- **Rootkit:** se trata de un tipo de herramientas de ofuscación que están diseñadas para ocultar procesos, archivos o registros de sistema, permitiendo que los atacantes mantengan acceso persistente sin ser detectados.
- **Botnets:** redes de dispositivos “zombificados” representan una de las amenazas más versátiles y potentes del panorama actual. La red se compone, normalmente, de diversos dispositivos infectados y controlados de forma remota por uno o varios ciberdelincuentes
- **Rogueware:** *software* fraudulento que simula ser una herramienta legítima de seguridad o limpieza. Muestra alertas falsas de infección para engañar a usuarios y extorsionar pagos.
- **Criptojacking:** secuestro encubierto de los recursos computacionales con el propósito de minar criptomonedas sin autorización. Se propaga mediante

scripts en navegadores, infecciones de software o compromiso de infraestructuras *cloud*. Reduce en gran medida el rendimiento de los dispositivos y aumenta los costes energéticos.

- **Apps maliciosas:** se trata de aplicativos que ocultan funcionalidades dañinas bajo apariencia legítima. Roban datos, muestran publicidad agresiva o suscriben servicios premium no solicitados. Utilizan, además, técnicas de ofuscación.

2.6. Ciclo de vida de un incidente

Una vez analizadas las principales amenazas, estamos en disposición de definir el ciclo de vida de un incidente de seguridad informática:



Figura 11. Fases de la gestión de una crisis.
Fuente: INCIBE

En la figura 11 se muestra – de forma gráfica – las fases en las que se divide la gestión de una crisis, para definir el ciclo de vida de incidentes en este TFG se toma como referencia el Procedimiento de Gestión de Ciberincidentes para el sector privado y la ciudadanía que nos brinda INCIBE [15]

Cada una de las fases conlleva un conjunto de acciones asociadas principalmente a evitar que los incidentes ocurran y, en caso de que se produzcan, a mitigar, en la medida de lo posible, sus efectos y restaurar la operatividad de la empresa en el menor tiempo posible.

2.6.1. Preparación

Se trata de una fase fundamental en la gestión de incidentes de seguridad informática, en ella se definen las bases para que la organización esté preparada para dar una respuesta eficaz ante un incidente. Con este objetivo, podemos definir la fase de preparación en tres aspectos clave:

- Preparación del equipo de respuesta y garantía de comunicaciones:

Es muy importante tener bien definido el equipo que dará respuesta a la incidencia, el personal designado a tal efecto debe estar perfectamente identificado y estar capacitado para, en la medida de lo posible, hacer frente a la situación. En ocasiones, debido a la naturaleza de la organización, si no se dispone de personal suficiente se puede contar con un equipo de respuesta externo.

Por otra parte, para asegurar las comunicaciones en todo momento, se debe tener actualizado un listado de contactos y con múltiples vías – teléfono, email, correo electrónico personal y corporativo, etc. – de esta forma en caso de que la comunicación no sea posible existan métodos alternativos de comunicación – tanto interna como externa -. Además, si se cuenta con métodos de comunicación cifrada estos deben ser probados y evaluados periódicamente.

- Herramientas para la gestión de un incidente:

Es de vital importancia que los recursos y herramientas necesarios para hacer frente a los posibles incidentes de ciberseguridad estén preparados en soportes de almacenamiento extraíble.

Para acelerar la recuperación y garantizar la continuidad del negocio, se debe poder acceder a imágenes del sistema seguras y operativas. Es crucial probar y registrar los procedimientos de recuperación. Además, se debe garantizar que existan dispositivos para que las pruebas y otros materiales sensibles recopilados durante el incidente se puedan almacenar de forma segura.

- Preparación del resto de personal y medidas preventivas:

La responsabilidad no recae únicamente en el equipo de respuesta y, por tanto, con el objetivo de que los usuarios estén concienciados de la utilización de los sistemas corporativos de forma responsable, es necesario llevar a cabo iniciativas de formación y sensibilización.

Además, llevar a cabo simulacros y los ejercicios de entrenamiento son una excelente manera de poner a prueba los procedimientos, las estrategias y la preparación del personal en un entorno seguro que imite escenarios reales.

Junto con estas medidas deben utilizarse una serie de medidas técnicas preventivas, como, por ejemplo, parches, software antivirus, etc., para protegerse contra vulnerabilidades, virus e intrusiones.

Finalmente, resulta conveniente una minuciosa evaluación de los activos de la empresa por medio de un análisis de riesgos y, además, llevar a cabo una serie de procedimientos con el objeto de tener perfectamente identificados los activos de la empresa y las amenazas, evaluar la probabilidad de impacto sobre

la actividad y tener perfectamente definido una estrategia para tratarlos: ya sea mitigar, transferir o asumir.

2.6.2. Identificación

Llegado este momento, el objetivo principal es saber discernir entre los sucesos cotidianos en el funcionamiento de la empresa y las anomalías que puedan llevar consigo un problema de seguridad. Puesto que los eventos se evalúan continuamente, esta fase es completamente iterativa con la fase de preparación. Si un evento necesita ser examinado, pasa a la fase de identificación, en cambio, si es rechazado, vuelve a la supervisión en la fase de preparación.

Por tanto, se pone de manifiesto la importancia de definir una serie de aspectos claves de la identificación de incidentes:

- Pleno conocimiento del estado normal en el que opera la organización.
- En el preciso instante en que se identifica un potencial incidente, únicamente el personal implicado en la gestión de este debe tener información.
- Conocimiento de los vectores de ataque más utilizados por los ciberdelincuentes.

Por otra parte, la organización debe recurrir a diversas fuentes de información con el objetivo de corroborar y analizar en incidente, en la tabla 7 se muestran las acciones más relevantes organizadas por niveles.

Fuentes de análisis de posibles incidentes:		
A nivel de red	Análisis de registros	Cortafuegos
		Proxies
		Tráfico
		Conexiones sospechosas
	Alerta en sistemas (En caso de que existan)	SIEM
		NIDS/NIPS
A nivel de equipo	Examen exhaustivo de los equipos	NDLP
		Cuentas de usuario anómalas
		Archivos sospechosos
		Procesos inusuales
		Alta carga del sistema
		Conexiones inusuales
A nivel de aplicación	Revisión de Logs de aplicaciones	Entradas de registro
		Alertas e informes de antivirus
		Detectar accesos no autorizados o actividades anómalas de los usuarios

Fuentes externas	Búsqueda de información	Reportes de usuarios externos
		Avisos sobre vulnerabilidades
		Información en RRSS

Tabla 7. Fuente de análisis de posibles incidentes.

2.6.3. Contención

En esta fase ya se ha confirmado el incidente y, por tanto, se debe dar respuesta con inmediatez para intentar detener el daño e intentar que este no aumente. Podemos dividir la fase de contención en dos subfases: la contención propiamente dicha y la realización del análisis del incidente.

1. Contención:

En primer lugar, el objetivo debe ser evitar que el ataque se expanda de forma lateral por la red y que pueda sustraer más datos. Además, las decisiones y los pasos a seguir deben de producirse con la máxima celeridad.

Seguidamente, resulta crucial la clasificación en función del tipo incidente para asignar las prioridades y los recursos empleados de manera objetiva. Además, debe ser una clasificación dinámica.

Por otra parte, es de gran importancia la documentación de cada acción que se lleve a cabo y de cada decisión que se tome junto con una correcta comunicación del incidente a los niveles superiores.

Finalmente, se deben de tomar las acciones de contención que resulten necesarias:

Acciones de contención inmediatas	
Aislamiento en la red	Desconectar de la red el equipo afectado o el segmento de la red
Segmentación	Mover el recurso comprometido a una VLAN aislada o colocar un firewall que filtre el tráfico
Contramedidas técnicas	En función del tipo de ataque
Coordinación externa	Contactar con proveedores de Internet o equipos de respuesta como INCIBE-CERT

Tabla 8. Acciones de contención inmediatas.

2. Análisis:

Una vez se controla la situación es crucial la recopilación de pruebas para, de esta forma, determinar el alcance real del ataque, así como para cualquier procedimiento futuro.

El primer paso del proceso de análisis forense es utilizar herramientas especializadas que garanticen que el entorno permanezca inalterado para capturar los datos volátiles de la RAM, evitando que se produzca la pérdida irreversible cuando se apaga el sistema.

A continuación, se debe apagar rápidamente el sistema cortando la alimentación para impedir que cualquier *malware* inicie actividades de autodestrucción.

Finalmente, mediante un hardware *write-blocker* se crean copias exactas bit a bit de los datos no volátiles de los discos duros, manteniendo la integridad de los originales. Por último, se aplica una función hash criptográfica a las pruebas originales y sus copias para demostrar la integridad de todo el material recopilado. Esto produce un identificador único que certifica que las pruebas no han sido alteradas durante el proceso.

2.6.4. Mitigación

En la fase de mitigación es en la que se deben restaurar los sistemas a un estado seguro, eliminando las causas que provocaron el incidente y recuperar la operatividad. Las estrategias a llevar a cabo varían en función de del tipo de ataque, algunas de las medidas a llevar a cabo durante la mitigación pueden ser:

Mitigación y recuperación		
Estrategia	Aplicación	Acciones
Reinstalación limpia	Pese a que no siempre es posible, se trata de la medida más segura	Borrado seguro del medio de almacenamiento
		Reinstalación del sistema operativo y aplicaciones desde los medios originales
Restauración desde <i>Backup</i>	En caso de disponer copia limpia.	Restaurar el sistema con una copia de seguridad anterior a la fecha del incidente

Limpieza del sistema con Antivirus	En caso de amenazas conocidas y no persistentes	Utilizar soluciones de fabricantes para detectar y eliminar malware identificado
		Ineficaz contra amenazas avanzadas
Mitigación Especializada (DDoS)	Para ataques que saturan los servicios	Solicitar asistencia de proveedores externos de mitigación
		Coordinar con un CSIRT
Endurecimiento del Sistema	Paso necesario tras cualquier tipo de reinstalación o restauración de los sistemas	Actualizar el Sistema Operativo y aplicaciones
		Restaurar las contraseñas
		Revisar todos los servicios que han quedado expuestos
		Analizar y reducir la superficie de ataque
Migración Manual de Datos	En caso de no existir <i>backups</i>	Extraer manualmente la información del equipo o equipos comprometidos. Para transferirla al nuevo sistema extremar las precauciones para no reintroducir la infección.
Auditoría de Seguridad	Paso final antes de volver a operar.	Realizar una auditoría para verificar el nivel de protección.
		Garantizar que la puesta en producción es segura

Tabla 9. Medidas fase de mitigación

2.6.5. Recuperación

El objetivo principal de la fase de recuperación es el restablecimiento de la operatividad del sistema y recuperar el normal funcionamiento. Es imprescindible no precipitarse al volver a poner en producción los sistemas comprometidos.

Con el objeto de detectar cualquier posible indicio de actividades sospechosas que pueda suponer la reaparición del problema, como, por ejemplo, procesos extraños, cuentas de usuario no autorizadas o conexiones desconocidas, es necesario llevar a cabo una supervisión exhaustiva durante esta fase.

Es fundamental programar las paradas de mantenimiento que sean necesarias y seguir las instrucciones de restauración especificadas por los fabricantes de los sistemas importantes. Además, hay que estar preparado para la posibilidad de que el incidente se repita, en este caso habría que volver a aplicar las fases de contención y erradicación.

El personal responsable y los administradores del sistema deben trabajar conjuntamente para comprobar el correcto funcionamiento.

2.6.6. Post-Incidente

Fase final del ciclo de vida de incidentes, se llega a ella en el momento que la amenaza ha sido controlada y se ha recuperado la normalidad operativa. Resulta fundamental, ya que es en este momento en el que reflexiona profundamente sobre lo ocurrido y se analizan las lecciones aprendidas.

Lleva implícito un riguroso análisis sobre las causas subyacentes del problema, las medidas que han sido adoptadas – acertadas o no - durante la gestión del incidente y los contratiempos que hayan podido surgir.

2.7. Gobernanza y marcos de la ciberseguridad

Mediante el uso de unas estructuras organizativas bien definidas, políticas escritas y mecanismos de control, la gobernanza de la seguridad informática crea el marco que permite a las empresas gestionar de forma proactiva los riesgos digitales y adaptar su estrategia de seguridad a los objetivos empresariales. Los conceptos de gestión de riesgos, asignación de responsabilidades y cumplimiento normativo se incorporan a este sistema de gobernanza.

Toda estructura sólida de gobernanza de ciberseguridad debe sustentarse en tres pilares básicos:

- En primer lugar, una recopilación de documentos que funcionen como marco normativo para establecer directrices sobre el tratamiento de la información empresarial, incluyendo políticas, normas, procedimientos y directrices.

- Otro factor importante a tener en cuenta es la definición de los puestos relevantes, entre los que se incluyen una serie de puestos clave como el CISO, el comité de seguridad y otros que puedan definirse. Su objetivo principal es el de supervisar y garantizar que se cumplan todas las normas. Además, este pilar garantiza que la seguridad cuente con liderazgo y responsabilidad.
- Por último, los responsables facilitan la evaluación y la mejora continua de la seguridad mediante inspecciones rutinarias y otros procedimientos, como auditorías y revisiones de cumplimiento.

2.7.1. Roles principales

A continuación, desglosaremos los roles principales y sus responsabilidades [25] en materia de seguridad informática.

Roles principales y responsabilidades			
Rol	Definición (en castellano)	Responsabilidad	Funciones
CEO	Director Ejecutivo	Máxima	Establecer la cultura de seguridad, garantizar los recursos económicos, humanos y tecnológicos. Liderar la estrategia general.
CSO	Director de Seguridad	Alta	Seguridad tanto física como tecnológica
CISO	Director de Seguridad de la Información	Alta	Gestionar la estrategia, políticas y los riesgos de la información. Coordinar el equipo de ciberseguridad y la concienciación. Perfil técnico y estratégico.
CIO	Director de Información	Alta	Asegurar la efectividad de la tecnología. Supervisar proyectos TI. Colaborar con el CISO en seguridad informática. Perfil técnico
CTO	Director de Tecnología	Alta	Investiga nuevas tendencias y gestiona proyectos tecnológicos. Perfil técnico

CDO	Director de Datos	Alta	Asegurar el cumplimiento legal. Gestionar la privacidad y la estrategia de datos.
Hacker Ético	Simula ataques con la intención de identificar y corregir posibles vulnerabilidades	Media	Realiza <i>tests</i> de penetración para identificar vulnerabilidad de forma proactiva. Puede ser interno o externo. Perfil técnico
DPD	Delegado de Protección de Datos	Alta	Asegurar que se cumple con la legislación en materia de protección de datos. Puede ser figura interna, externa o compartida.
Equipo de formación y concienciación	Equipo multidisciplinar para mejorar la concienciación y las buenas practicas	Media	Concienciar en materia de seguridad informática. Puede incluir roles de: Ciberseguridad, Comunicación, TI, Respuesta a Incidentes y Recursos Humanos.
Resto del personal	Empleados y usuarios finales de los sistemas	Baja	Aplicar buenas prácticas. Cumplir con las políticas de seguridad y la formación recibida.

Tabla 10. Roles y responsabilidades

2.8. Metodología utilizada en la simulación del caso práctico

Con el objetivo de comprobar y de validar la viabilidad del sistema de gestión de incidentes propuesto en este TFG, se han definido tres incidentes aplicados a una empresa ficticia.

2.8.1 Conceptos previos

Previamente a describir la simulación es conveniente poner en contexto una serie de conceptos que serán utilizados en la gestión de los incidentes y que posteriormente se desarrollarán.

- **Incidente de seguridad informática:** se trata de cualquier tipo de evento adverso del cual se tenga la certeza o exista la sospecha de que comprometa, o pueda llegar a hacerlo, la confidencialidad, la integridad y/o la disponibilidad de los datos o sistemas de la propia organización.

- **Ciclo de vida de un incidente:** comprenden el conjunto de fases que se han desarrollado en el apartado 2.6 de este trabajo: preparación, identificación, contención, mitigación, recuperación y, finalmente, post-incidente.
- **Factor de criticidad del incidente:** se trata del nivel de impacto que se asigna a un incidente en función de la repercusión que puede llegar a suponer para la corporación.
- **Indicadores de rendimiento (KPIs):** con el objetivo principal de evaluar la eficacia del sistema, se calcularán tres indicadores clave que serán definidos posteriormente en la sección 3.4 de este TFG:
 - ***Mean Time to Detect:*** mide el tiempo necesario para la detección desde el momento en el que se inicia.
 - ***Mean Time to Recovery:*** mide el tiempo medio que necesita la corporación para volver a su estado normal previo al incidente.
 - ***Tasa de falsos positivos:*** esta tasa refleja la cantidad de alertas generadas por las herramientas utilizadas en la monitorización que no llegan a suponer un riesgo real.
- **Brecha de seguridad:** se trata de cualquier incidente que lleve implícito un acceso a datos personales y que, normalmente, conlleva la notificación a la autoridad competente.

2.8.2 Descripción de la empresa

La finalidad del sistema propuesto en este Trabajo Final de Grado es que sea adaptable a cualquier tipo de organización, no obstante, con el objetivo de poner en práctica dicho sistema, se define una empresa como ejemplo.

Se trata de una empresa dedicada al sector de la medicina: *PearTrees Medical Services*, la cual tiene como objetivo la gestión de varios centros médicos y de proporcionar servicios de laboratorio clínico.

La empresa cuenta con 240 empleados (155 de la empresa y 85 en servicios subcontratados), los cuales se distribuyen en tres sedes y, además, cuenta con un laboratorio y una planta de oficinas. Por las particularidades de la empresa su nivel de digitalización es elevado.

La empresa está radicada en la isla de Mallorca y sus sedes son:

- Clínica principal Palma
- Clínica Sóller
- Clínica Manacor

Los 240 empleados se distribuyen de la siguiente manera:

- Dirección general (CEO).
- 75 profesionales médicos y especialistas, distribuidos:
 - Clínica Palma: 35
 - Clínica Sóller: 20
 - Clínica Manacor: 20
- 25 profesionales de Laboratorio Clínico, distribuidos:
 - Análisis Clínicos: 15
 - Hematología: 5
 - Microbiología: 5
- 40 profesionales del Departamento de Administración:
 - Admisión y Facturación: 20
 - Documentación sanitaria: 10
 - RRHH: 5
 - Compras: 5
- 15 profesionales del Departamento IT:
 - Soporte Técnico: 6
 - Infraestructuras: 5
 - Seguridad IT: 4
- Aproximadamente 80 empleados externalizados distribuidos en: auxiliares de enfermería, mantenimiento, seguridad, limpieza, etc. Este número es orientativo ya que va cambiando según las necesidades.

A grandes rasgos, su infraestructura tecnológica esta distribuida de la siguiente forma:

- Servidor dedicado a las historias clínicas:
 - Localización física: Palma
 - Configuración: Clúster activo/pasivo
 - Software: Sistema de Historia Clínica Electrónica basado en estándares HL7/FHIR [26].
 - BBDD: PostgreSQL 14
 - Datos almacenados: 12 TB (5 años de historiales)
- Sistema de laboratorio:
 - Software: Sistema de Información de Laboratorio (LIS) estándar del sector
 - Conectado a 8 equipos analizadores automáticos.

- Interfaz: HL7 con HCE
- Servidor para imágenes diagnósticas:
 - Sistema PACS (*Picture Archiving and Communication System*)
 - Almacenamiento: 40 TB (RX, TAC, RMN)
 - Estándar: DICOM
 - 3 estaciones de diagnóstico (una por sede)
- Servidor VPN (telemedicina y acceso remoto a los sistemas):
 - Máximo 60 usuarios al mismo tiempo.
 - Autenticación: AD + tokens OTP
 - Segmentación: solo VLAN administrativa
- Arquitectura de red: Internet (500 Mbps), Firewall (FortiGate 100F), Core Switch (Cisco 2960X)
- Segmentación de la red en VLANs: clínica, administración, laboratorio, diagnóstico y dispositivos externos:
 - **VLAN 10:** ADMINISTRACIÓN (192.168.10.0/24)
 - **VLAN 20:** CLÍNICA (192.168.20.0/24)
 - **VLAN 30:** LABORATORIO (192.168.30.0/24)
 - **VLAN 40:** DIAGNÓSTICO (192.168.40.0/24)
 - **VLAN 99:** DISPOSITIVOS (192.168.99.0/24)

La comunicación entre sedes:

- Palma↔ Sóller: VPN site-to-site (50 Mbps)
- Palma↔Manacor: VPN site-to-site (50 Mbps)
- Laboratorio y edificio anexo de administración conectados directamente a la sede de Palma mediante fibra propia.

Cabe destacar que la empresa, debido a su actividad, trata una serie de datos que resultan especialmente protegidos por la GDPR además de información financiera de pacientes.

Por otra parte, existe a disposición de la empresa la siguiente documentación relacionada con la gestión de incidentes de seguridad informática y con la continuidad del negocio:

- Política de Seguridad: genérica y desactualizada.
- Procedimiento de *Backup*: diario incremental.
- Procedimiento Operativo de Gestión Básica de Incidentes
- Plan de Continuidad: básico (48 horas de recuperación)

Los controles implementados en los sistemas son los siguientes:

- Antivirus en todos los equipos corporativos *Bitdefender*

- *Firewall* Perimetral
- *Backups* diarios con retención de 30 días
- Formación periódica en seguridad

Finalmente, en la siguiente gráfica, se muestra la madurez de la empresa en materia de ciberseguridad:

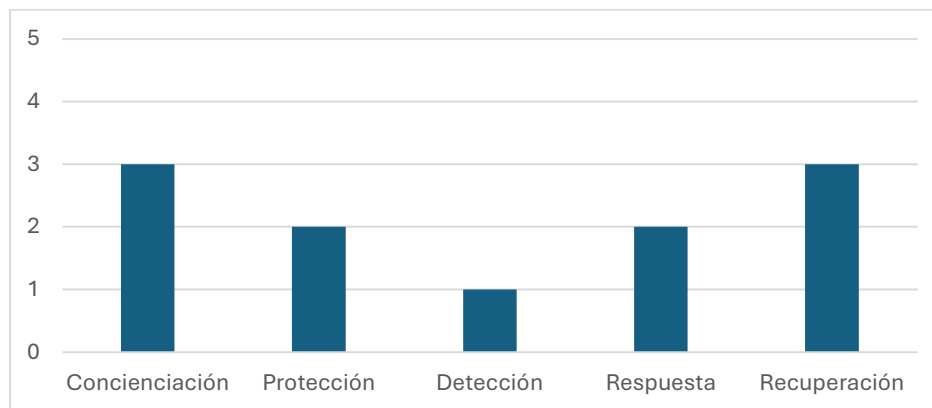


Figura 12. Madurez de ciberseguridad de la empresa

La concienciación del personal de la corporación se evalúa en 3/5 ya que únicamente se tiene constancia de formación en la materia sin especificar si se realizan o no simulacros, ejercicios etc.

La protección de los sistemas 2/3 se basa en una serie de controles básicos sin existir una defensa en profundidad.

En lo relativo a la detección encontramos el valor más bajo en esta escala 1/5 ya que se basa únicamente en sistemas de detección manual sin la existencia de una monitorización proactiva.

Para la respuesta ante incidentes 2/5, encontramos que los procedimientos son básicos y que no están debidamente ejercitados.

Finalmente, la recuperación de los sistemas 3/5 debido a la existencia de *backups* y de un EDR básico.

Se ponen de manifiesto una serie de puntos débiles que pueden llegar a resultar críticos como, por ejemplo:

- Ausencia de SGCI formalizado
- La detección de incidentes es reactiva ya que esencialmente está basada en los usuarios.
- La segmentación resulta insuficiente (VLANs muy básicas)
- Para el acceso remoto se utilizan credenciales muy simples.

2.8.3 Análisis de impacto en el negocio BIA

Con el objetivo de evaluar los riesgos a los que la corporación se enfrenta, resulta conveniente una evaluación previa del impacto que puede llevar asociado un incidente grave que afecte a los activos de la organización, de forma general, debemos determinar:

- Las actividades principales de la organización.
- Los procesos externos de los que dependemos
- Los tiempos máximos que el sistema puede permanecer sin esas actividades.
- Los tiempos mínimos de recuperación de los servicios.

La empresa que tomamos como ejemplo para la realización del caso práctico de este TFG tiene una serie de actividades esenciales, como resultado del análisis BIA realizamos la siguiente tabla:

Análisis de impacto en el negocio						
Nº	Actividad	Clasificación	MTPD	RTO	RPO	Dependencia crítica
1	Historial Clínico	CRÍTICA	1 hora	30 min	0 horas	Básico para consulta y laboratorio
2	Consulta y Diagnóstico	CRÍTICA	1 hora	15 min	0 horas	Depende de historial clínico y de laboratorio
3	Laboratorio Clínico	ALTA	4 horas	2 horas	1 hora	Depende del estado de la red interna y de historial clínico
4	Admisión y Citas	ALTA	8 horas	4 horas	24 horas	Depende del estado de la red interna y del sistema de citas
5	Telemedicina	MEDIA	24 horas	12 horas	4 horas	Depende de internet y del historial clínico
6	Facturación	MEDIA	72 horas	24 horas	24 horas	Datos de consulta y admisión

Tabla 11. Análisis BIA

Este análisis de impacto en el negocio contiene los datos mínimos relevantes para, una vez desarrollado el caso práctico, poder evaluar si se han cumplido los objetivos marcados en él. A continuación, se desarrollan algunos de los datos que se muestran:

MTPD (*Maximum Tolerable Period of Disruption*), es el tiempo máximo que una actividad crítica puede sufrir una interrupción antes de que el daño para la empresa llegue a ser irreversible, independientemente de que posteriormente se recupere la normalidad.

RTO (*Recovery Time Objective*), es el tiempo máximo evaluado de forma objetiva en el que un sistema se debe recuperar tras un incidente.

RPO (*Recovery point Objective*), es la cantidad máxima de datos/pérdida de tiempo que puede resultar aceptable. Es decir, no se trata del tiempo en el que el sistema permanece parado sino “cuánto retrocedes en el tiempo” una vez recuperado.

2.8.4 Simulación de incidentes

A modo de validación del sistema de gestión de incidentes propuesto, definiremos una serie de incidentes de seguridad informática que serán simulados para una integral valoración de todas las fases del ciclo de vida incidentes que se han descrito en los apartados anteriores.

A tal efecto, se definen los criterios utilizados para la elección de dichos incidentes:

1. Se seleccionarán incidentes que se registran con relativa frecuencia en entornos corporativos reales.
2. Se tendrá en cuenta el posible impacto potencial sobre los aspectos clave: confidencialidad, integridad y disponibilidad de los activos de la empresa.
3. Servirán para medir la capacidad de detección, contención, mitigación y recuperación.
4. Estarán alineados con las principales amenazas identificadas en el capítulo 2 de este TFG y con los estándares ISO/IEC 27035 y NIST SP 800-61.
5. El primer incidente será el principal y el que conllevará la mayor dedicación de este TFG, los dos siguientes se utilizarán a modo de apoyo y con el objetivo de realizar una comparativa final.

En base a estos criterios, en la tabla 12, se definen los incidentes a simular en este Trabajo de Final de Grado:

Incidentes simulados						
Nº	Tipo de ataque	Vector	Activos comprometidos	Objetivos del ataque	Impacto principal (CIA)	Fases del ciclo especialmente críticas
1	Ransomware	Correo electrónico malicioso / explotación de vulnerabilidad	Servidores corporativos, sistemas críticos, datos	Cifrado de información y extorsión económica	Disponibilidad e integridad	Detección, contención, recuperación
2	Phishing (compromiso de credenciales)	Ingeniería social mediante correo electrónico	Cuentas de usuario, sistemas de autenticación	Obtención de credenciales y acceso no autorizado	Confidencialidad	Detección, clasificación, mitigación

3	Malware con acceso no autorizado	Descarga de <i>software</i> malicioso / dispositivo comprometido	Equipos de usuario, red interna	Persistencia y movimiento lateral	Integridad y confidencialidad	Contención, erradicación
---	---	--	---------------------------------	-----------------------------------	-------------------------------	--------------------------

Tabla 12. Incidentes simulados en el caso práctico

2.8.5 Metodología de la simulación

Para llevar a cabo la validación del sistema se ha utilizado una simulación controlada en un entorno corporativo ficticio – definido en el apartado 2.8.2 de este TFG-. Mediante esta metodología podemos evaluar la aplicabilidad práctica de todos los procedimientos que han sido previamente definidos a lo largo de este Trabajo Final de Grado sin llegar a comprometer, en ningún caso, sistemas reales.

Esta simulación está basada en ataques previamente definidos, los cuales reproducen una serie de incidentes de ciberseguridad que son recurrentes en entornos corporativos – definidos en el apartado 2.8.3 de este TFG-.

Cada uno de los incidentes propuestos se desarrolla siguiendo una secuencia temporal perfectamente definida y estructurada para conseguir un análisis de la respuesta de la organización a lo largo de todas las fases del ciclo de vida del incidente.

Por tanto, la metodología aplicada se encuentra alineada, en todo momento, con las guías de referencia ISO/IEC 27035, el NIST SP 800-61 y las guías de gestión de incidentes publicadas por INCIBE.

La estructura de la simulación está basada en las fases definidas en el apartado 2.6 de este TFG: Ciclo de vida de un incidente. Preparación, identificación, contención, mitigación, recuperación y análisis post-incidente.

Por otra parte, en la ejecución de la simulación, son evaluados una serie de elementos y capacidades de la empresa en la gestión de este tipo de incidentes:

- Una correcta aplicación de todos y cada uno de los roles y de las responsabilidades definidas en el apartado 2.7.1 de este TGF.
- La correcta utilización de la documentación de apoyo.
- Los tiempos de respuesta que están asociados a cada una de las fases del incidente.

Además, para evaluar los resultados obtenidos en la simulación, se utilizan una serie de indicadores de rendimiento (KPIs), los cuales permiten, de una forma objetiva, analizar la eficacia del sistema y su capacidad de mejora ante un incidente.

3. Resultados

3.1. Visión general de los resultados obtenidos

En términos generales, los resultados obtenidos en la simulación del caso práctico, con sus tres incidentes, son:

- Desarrollo de un caso práctico basado en la simulación de tres incidentes de seguridad representativos de amenazas reales en el sector sanitario: *ransomware*, *phishing* y *malware*, aplicados a la empresa ficticia *PearTrees Medical Services*.
- Mediante el desarrollo de este caso práctico se ha puesto en funcionamiento el procedimiento de gestión de incidentes en el que se basa este TFG, evaluando su posible aplicación en un entorno real y alineado con la infraestructura, los activos críticos y la estructura organizativa de la empresa.
- A lo largo de la simulación se han analizado las distintas fases del ciclo de vida del incidente, desde la detección y el registro inicial hasta su clasificación, gestión, cierre y análisis posterior.
- Con el objetivo de evaluar la eficacia del procedimiento que se ha aplicado, se han utilizado indicadores clave de rendimiento (MTTD, MTTR y tasa de falsos positivos), que han permitido identificar las fortalezas y las debilidades existentes en los mecanismos de detección y respuesta ante incidentes.
- Los resultados obtenidos han sido contrastados con el Análisis de Impacto en el Negocio (BIA), verificando el nivel de cumplimiento de los objetivos de continuidad del negocio y la adecuación de los tiempos de respuesta en función de la criticidad de los servicios que se han visto afectados.
- Para finalizar, todos los aspectos anteriores nos han permitido realizar un análisis global de los resultados y, por tanto, ha sido posible extraer una serie de conclusiones orientadas a la mejora del nivel de madurez en la gestión de incidentes de seguridad informática, especialmente en todo lo relativo a la detección temprana y a la optimización de los procesos de respuesta.

En los apartados siguientes se desarrollan todos estos puntos de forma detallada.

3.2. Documentación de apoyo

En este apartado se definen una serie de herramientas basadas en documentación de apoyo las cuales sirven para garantizar una gestión perfectamente estructurada y homogénea. Estos documentos figuran – a modo de plantillas- en los anexos de este TFG.

Mediante el uso de estos documentos se asegura la trazabilidad de los incidentes, la correcta asignación de responsabilidades y la obtención de información relevante para su análisis posterior.

A continuación, se hace un desglose del contenido de cada uno de estos documentos:

DOCUMENTO DE REGISTRO Y GESTIÓN DE INCIDENTES:

Documento esencial para la gestión de cualquier incidente de seguridad informática, se redacta al inicio y en él se recoge información básica como, por ejemplo, fecha y hora de detección, el activo afectado, el tipo de incidente, el nivel de criticidad y las acciones iniciales realizadas.

Este documento sirve como punto de partida para el seguimiento del incidente a lo largo de todos los ciclos por los que pasa hasta su finalización, garantizando, de esta forma, la trazabilidad y el seguimiento del incidente.

La plantilla de este documento utilizada en este Sistema de Gestión de Incidentes la podemos encontrar en el ANEXO A.

CLASIFICACIÓN Y NIVEL DE CRITICIDAD:

Documento en el cual se define los criterios necesarios para clasificar y evaluar la criticidad de los ciberincidentes. La clasificación debe estar basada en el impacto y la urgencia relacionada con el incidente.

En este TFG, clasificaremos los incidentes de seguridad informática según los criterios expuestos por INCIBE en su Guía Nacional de Notificación y Gestión de Ciberincidentes [27, 14].

- **Clasificación según su nivel de peligrosidad:**



Figura 13. Niveles de peligrosidad del ciberincidente

- **Según su impacto en la organización:**



Figura 14. Niveles de impacto de un ciberincidente

La plantilla elaborada a tal efecto puede encontrarse en el ANEXO B de este TFG, junto con las tablas que nos proporciona INCIBE para definir los niveles de impacto.

DOCUMENTO DE ASIGNACIÓN Y COMUNICACIÓN DE ROLES Y RESPONSABILIDADES

Para una gestión eficiente de cualquier incidente de seguridad informática es necesario definir de forma clara y concisa tanto los roles como las responsabilidades de los actores implicados. La plantilla de este documento la podemos encontrar en el ANEXO C.

PROCEDIMIENTOS OPERATIVOS DE RESPUESTA:

Conjunto de documentos internos en los cuales se describen los procedimientos operativos de respuesta ante los principales incidentes de seguridad informática. En ellos se establecen una serie de criterios y acciones a seguir para garantizar una respuesta lo más rápida posible primando, en todo momento, la eficacia.

En el ANEXO D se aporta un documento previo de la empresa el cual será utilizado en la simulación práctica a modo de Procedimiento Operativo ante este tipo de incidentes. No ha sido desarrollado en su totalidad, únicamente se desglosan los aspectos necesarios para la realización de este caso práctico.

PLANTILLAS DE INFORMES y KPIs:

Con el objetivo de evaluar la eficacia del sistema de gestión de incidentes y facilitar la mejora continua se elabora un informe post-incidente – ANEXO E- el cual contiene los indicadores clave de rendimiento:

- **Informe post-incidente:** Una vez controlado el incidente y restableciendo los sistemas a niveles previos al mismo, se debe elaborar un informe que contenga: resumen ejecutivo del incidente, cronología, impacto en el sistema, medidas adoptadas y, finalmente, las lecciones aprendidas.
- **MTTD:** Representa el tiempo medio transcurrido desde que se produce un incidente hasta que es detectado por la organización.
- **MTTR:** Mide el tiempo medio necesario para resolver un incidente de ciberseguridad desde el momento en que este ha sido detectado hasta su completa resolución y cierre
- **Tasa de falsos positivos:** Representa la proporción de eventos identificados inicialmente como incidentes de seguridad que, tras su análisis, resultan no ser incidentes reales.

3.3. Caso práctico

3.3.1. Contexto y escenario previo del incidente

La empresa *PearTrees Medical Services*, la cual pertenece al sector sanitario y está dedicada a la gestión de centros médicos complementada con la prestación de servicios de laboratorio. En la actualidad, la empresa se encuentra completamente operativa y prestando servicios de forma ininterrumpida.

La organización cuenta con un elevado nivel de digitalización y una infraestructura tecnológica la cual se encuentra distribuida entre tres sedes - Palma, Sóller y Manacor- y, además, cuenta con un laboratorio centralizado y una planta de oficinas, ambos anexos al edificio de la sede de Palma. Este contexto convierte a los sistemas de información en un elemento altamente crítico para el desarrollo de su actividad asistencial.

Actualmente, la empresa dispone de un marco básico para la gestión de incidentes de seguridad informática -incluido en el ANEXO D de este TFG- el cual es muy genérico y poco actualizado.

Por otra parte, el personal de la empresa cuenta con un nivel de concienciación en materia de seguridad informática que podríamos considerar medio. La empresa realiza periódicamente acciones formativas dirigidas al personal en materia de prevención e identificación de amenazas. No obstante, este nivel de madurez presenta un amplio margen de mejora, especialmente en aspectos relacionados con la detección temprana y la optimización de los tiempos de respuesta.

3.3.2. Detección y registro del incidente

Hora	Situación
8:00	Inicio de la jornada con normalidad
9:30	Pico de usuarios en el sistema (75 conexiones al historial)
10:00	<i>Backup</i> diario completado
	Ejecución de <i>ransomware</i> mediante archivo adjunto
10:30	<i>Bitdefender</i> EDR lanza alerta
	Primer usuario reporta lentitud (sede Palma)
	Propagación lateral a HCE-SRV01 mediante credenciales comprometidas
10:45	Inicio cifrado base de datos PostgreSQL
	Múltiples quejas del funcionamiento del sistema
11:00	En el laboratorio se reporta que no se están recibiendo nuevas peticiones
11:15	Cifrado de 9,2 TB de los 12TB de la base de datos
	Usuario intenta acceder a historial y reporta ERROR 500
11:15	Activación incidente
11:20	Aparece nota solicitando rescate en múltiples dispositivos

Tabla 13. Cronología del incidente 1: *Ransomware*

Una serie de comportamientos anómalos en el sistema de historias clínicas alerta al personal sanitario durante su actividad habitual diaria. Se encuentra con la imposibilidad de acceder a determinados registros y se percata de una ralentización general del servicio, si bien en un principio no se considera algo relevante, los comentarios generalizados del resto de personal sobre estas anomalías hacen saltar las alarmas. Algo no va bien.

Paralelamente la solución de detección y respuesta de la entidad (EDR) genera una alerta debido a la detección de la ejecución de un archivo sospechoso. Pese a esto, la alerta es tratada como un evento más de seguridad y queda pendiente de ser analizada.

La incidencia es notificada al personal del departamento informático de la empresa y es este el que activa el proceso interno de gestión de incidentes de ciberseguridad, esta activación se produce una vez confirmada la indisponibilidad del sistema de historias clínicas y la afectación directa a servicios asistenciales y de laboratorio.

En este momento comienza una escalada del evento hasta llegar al responsable de seguridad de la información, quien decide abordar la situación asumiendo la coordinación inicial del incidente.

Una vez confirmado que lo que está ocurriendo no entra dentro del funcionamiento normal de los sistemas, tras entrevistar al personal implicado y haciendo uso la plantilla destinada a tal efecto – ANEXO A – se dispone a rellenar una serie de campos que resultan cruciales para la identificación del incidente en esta primera etapa.

REGISTRO Y GESTIÓN DE INCIDENTES DE CIBERSEGURIDAD		
Organización: <i>PearTrees Medical Services</i>		
Creador del documento:	Nombre: XXXXX	
	Apellidos: XXXXXXX XXXXXXXXX	
	Cargo: <i>Responsable de Seguridad de la Información</i>	
Versión del documento: 1.0		
Id: 2025-01	Fecha de detección: 02/10/2025	Hora de detección: 11:15

Estado del incidente:	Abierto	X	Tipo de incidente: <i>Posible ataque de ransomware con cifrado de datos confirmado</i>
	En curso		
	Cerrado		
Descripción inicial: <i>Se detectan una serie de anomalías en el sistema de historias clínicas electrónicas (HCE) de la empresa desde aproximadamente las 10:30 horas. Múltiples usuarios del sistema reportan imposibilidad de acceso a los registros médicos completos, se detecta una lentitud extrema e inusual del sistema, y un comportamiento errático en las interfaces. Los síntomas sugieren, una vez evaluados por el personal del departamento de informática, un posible cifrado parcial de datos, infección por malware o ataque dirigido a la disponibilidad del servicio. El incidente afecta inicialmente a la sede central de Palma, pero se va reportando la incidencia de forma progresiva desde las sedes de Sóller y Manacor.</i>			
Vector de ataque: <i>Pendiente de análisis forense. Posible phishing dirigido al personal administrativo (investigando email del 30/09) Vulnerabilidad en interfaz web del sistema HCE (CVE-2025-1234 no parcheada) Credenciales VPN comprometidas (se detectó conexión sospechosa desde IP polaca)</i>			
Activos potencialmente comprometidos: <i>Servidores de historias clínicas electrónicas. Base de datos de pacientes. Servidores de aplicación médica. Equipos de administración sanitario. Sistemas de backup conectados. Infraestructura de red interna</i>			
Nivel de criticidad estimado: <i>Alto; Afecta a un sistema crítico para la continuidad atención sanitaria, implica un alto impacto en la continuidad asistencial, posible riesgo para datos sensibles de salud (RGPD/LOPDGDD), y posible paralización de laboratorio central.</i>			
Plan de acción y contramedidas: Aislamiento inmediato: <i>Desconexión física de los servidores HCE-SRV01 y HCE-SRV02 de la red corporativa. Bloqueo de todo tráfico entrante/saliente en firewalls hacia la VLAN 20 (Clínica) Deshabilitar inmediatamente todos los accesos VPN y RDP externos Cambio inmediato de credenciales de administración de sistemas</i> Evaluación y contención: <i>Análisis forense inicial: captura de memoria RAM, logs de eventos, registros de firewall. Identificación del alcance: determinar qué sistemas adicionales están comprometidos Contención lateral: revisión de sistemas conectados a los servidores afectados. Comunicación a INCIBE a través del canal CSIRT-sector sanitario.</i> Comunicación y escalado: <i>Activación del Comité de Crisis (CEO, Director Médico, Director de Sistemas, RSI) Notificación a la Agencia Española de Protección de Datos (AEPD) - preliminar Comunicación interna: activación del protocolo de contingencia manual para historias clínicas Coordinación con laboratorio: procedimiento alternativo para recepción de peticiones</i>			
Responsable asignado: <i>Responsable de Seguridad de la Información</i>			
Observaciones: <i>Incidente detectado inicialmente por personal sanitario, no por sistemas de monitorización. Se evidencia necesidad urgente de mejorar capacidades de detección temprana. El laboratorio central aún opera de forma independiente, pero depende de datos clínicos para el procesamiento de muestras. Se recomienda activar protocolo de contingencia manual para atención urgente durante resolución.</i>			

Tabla 14. Registro de incidente

3.3.3. Clasificación y evaluación del incidente

El proceso de clasificación y evaluación se inicia una vez finalizado el registro del incidente, se siguen los criterios establecidos previamente y se utilizan las plantillas existentes en el ANEXO B. El objetivo principal de esta fase es determinar, de forma clara y concisa, el nivel de peligrosidad, el impacto y determinar la urgencia del incidente.

En lo relativo al impacto, el incidente afecta de forma directa a uno de los sistemas más críticos de los existentes en la organización -el servidor de historias clínicas- comprometiendo la disponibilidad de la información clínica la cual resulta esencial para la atención a los pacientes.

Por otra parte, es evidente que los datos de los pacientes se encuentran expuestos y esto supone un potencial riesgo tanto desde el punto de vista operativo como legal y reputacional.

Una vez evaluada la situación se procede a rellenar el Documento de Clasificación y Criticidad del Incidente:

En primer lugar, en lo relativo al nivel de peligrosidad del incidente, este se clasifica como “ALTO” ya que compromete un sistema crítico para la organización.

En cuanto al nivel de impacto que dicho incidente tiene en la organización, este provoca una interrupción en la prestación del servicio asistencial – principal ocupación de la corporación – durante un prolongado periodo de tiempo. Esta situación impacta de forma directa en la actividad médica con independencia de los riesgos legales y/o reputacionales que pueda llevar implícitos. Por tanto, se considera “ALTO”.

Finalmente, se considera que la probabilidad de éxito del ataque es “MUY ALTA” ya que la disponibilidad del servicio, con los datos existentes, ya se ha visto gravemente afectada. Además, el vector de ataque ha resultado exitoso ya que saltan las alarmas una vez los efectos del ataque ya son visibles. En base a los criterios evaluados se activa de forma inmediata del procedimiento operativo de respuesta y la asignación prioritaria de recursos para su gestión.

Por tanto, a modo de cuantificar el impacto en el funcionamiento de la empresa:

- 120 profesionales sin acceso a herramientas clínicas durante aproximadamente 5 horas.
- 35 consultas programadas canceladas.
- 12 pacientes urgentes atendidos sin acceso a los sistemas
- Datos comprometidos 76% del total (9,2 TB)

DOCUMENTO DE CLASIFICACIÓN Y CRITICIDAD DE INCIDENTES							
Id: 2025-01				Tipo de incidente: <i>Ataque de ransomware</i>			
Nivel de peligrosidad del incidente:							
Bajo	Incidentes fácilmente gestionables						
Medio	Incidentes que afectan a servicios no críticos						
Alto	Incidentes que comprometen sistemas críticos						X
Muy alto	Incidentes que afectan a >= 75% de los sistemas						
Crítico	Incidentes que afectan a >= 90% de los sistemas						
Niveles de impacto del ciberincidente:							
Sin impacto	No existe ningún impacto apreciable.						
Bajo	Interrupción de la prestación de un servicio.						
Medio	Interrupción en la presentación del servicio superior al 5% de usuarios.						
Alto	Interrupción en la prestación del servicio superior a 1 hora y superior al 10% de usuarios.						X
Muy alto	Interrupción en la prestación del servicio superior a 8 horas y superior al 35% de los usuarios.						
Crítico	Interrupción en la prestación del servicio superior a 24 horas y superior al 50% de los usuarios.						
Probabilidad de éxito del ataque:							
Baja		Media		Alta		Muy alta	X

Tabla 15. Clasificación y criticidad del incidente

3.3.4. Gestión del incidente

Una vez clasificado el incidente, se continua con el procedimiento estructurado. En este caso ha sido catalogado con una criticidad alta y esto conlleva que el

incidente sea gestionado en función de del P.O. definido en el ANEXO D y que sea coordinado según la matriz de responsabilidades definida en el ANEXO C.

Posteriormente a la clasificación del incidente se produce la confirmación y la aparición de evidencias muy claras que revelan que se ha producido un cifrado de datos y, junto con una nota de rescate en varios dispositivos, confirma la naturaleza del ataque.

En primer lugar, en la fase de contención, se adaptan una serie de medidas orientadas en todo momento a minimizar las consecuencias iniciales, limitando la propagación del incidente e intentando reducir su impacto sobre otros sistemas no afectados. Aprovechando la segmentación de la red corporativa se aísla el servidor afectado y, además, se restringe temporalmente los accesos remotos mediante VPN. Estas medidas iniciales permiten limitar la extensión del ataque al resto de entornos de la empresa.

Seguidamente, una vez limitada la propagación, comienza la fase de erradicación del incidente. En esta fase, el equipo técnico coordinado por el Responsable de Seguridad de la Información realiza un análisis del sistema afectado para identificar el *malware* responsable del incidente, eliminar los elementos maliciosos detectados y aplicar las medidas correctivas necesarias. De forma paralela, se revisan las credenciales de acceso al sistema y, de forma preventiva, se cambian las contraseñas asociadas a los sistemas críticos.

Una vez finalizada la erradicación, se inicia la recuperación del servicio, restaurando el sistema de historias clínicas partiendo de copias de seguridad previamente verificadas para, de esta manera, asegurar el correcto funcionamiento antes de su reincorporación a la red corporativa. Es en esta fase donde se realizan una serie de pruebas de validación para asegurar tanto la integridad como la disponibilidad de la información. Posteriormente, se reestablece de forma progresiva el acceso al sistema por parte de los usuarios de este hasta conseguir la recuperación de la operatividad normal de la empresa. La recuperación se inició a las 13:00 horas, completándose a las 16:00.

Resumen de acciones llevadas a cabo:

- Verificación de integridad del *backup*.
- Restauración en entorno aislado para validación previa
- Puesta en producción gradual de sistemas validados
- Monitorización intensiva post-recuperación

A continuación, en la siguiente tabla se muestra el protocolo de comunicación de crisis activado durante el incidente:

Protocolo de comunicación de crisis utilizado			
Hora	Destinatarios	Contenido del mensaje	Canal
11:45	Todo el personal	<i>Incidente técnico grave. Activar protocolo manual. No utilizar sistemas HCE.</i>	Email corporativo, WhatsApp grupal
12:00	Pacientes con cita	<i>Reprogramación citas no urgentes por incidencia técnica</i>	Llamada automática, SMS
12:30	AEPD	<i>Notificación brecha datos art. 33 RGPD: datos salud comprometidos.</i>	Sede electrónica AEPD
13:00	INCIBE-CERT	<i>Reporte ransomware sector sanitario.</i>	Formulario web INCIBE-CERT
14:00	Proveedores	<i>Contingencia activada. Coordinar entregas telefónicamente.</i>	Teléfono
16:30	Todo el personal	<i>Sistemas restaurados. Volver a operativa normal.</i>	Email corporativo, WhatsApp grupal

Tabla 16. Protocolo de comunicación de crisis.

3.3.5. Cierre del incidente

Finalmente, una vez reestablecidos los sistemas afectados y una vez verificada la su correcta recuperación, comienza la etapa de cierre formal del incidente. En esta fase se debe validar la resolución del incidente y si esta ha sido de forma satisfactoria y asegurando que no existan riesgos residuales asociados al incidente.

El equipo responsable realiza una revisión final del incidente, para confirmar el correcto funcionamiento de este y evaluar si se mantiene la disponibilidad, integridad y confidencialidad de la información gestionada por el sistema afectado. De igual forma que en procedimientos anteriores, se documentan todas las acciones que se han llevado a cabo durante la gestión del incidente, evaluando los tiempos de detección, respuesta y recuperación, utilizando las plantillas de informe definidas en el ANEXO E de este Trabajo Final de Grado.

Para finalizar, se identifican las lecciones que han sido aprendidas durante el incidente, una vez realizado un análisis *post-mortem* completo evaluando la necesidad de implementar una serie de mejoras a la mayor brevedad.

En este caso, destaca la necesidad de reforzar los procedimientos corporativos:

- Actualización del procedimiento de respuesta ante incidentes de seguridad informática.
- Revisión y mejora de los controles de seguridad.
- Programar ejercicios de simulación específicos con el personal.

Con la recopilación de todos estos datos se procede a realizar el informe post-incidente, a tal efecto se utiliza la plantilla del ANEXO E:

Informe post-incidente			
Id: 2025-01		Tipo de incidente: Ataque de ransomware con cifrado de datos	
Fecha de detección: 02/10/2025			
Fecha de resolución: 02/10/2025		Nivel de criticidad ALTO	
Resumen del incidente: Ataque de ransomware con cifrado de 9,2 TB de datos de historiales clínicos en el servidor HCE-SRV01, provocando 5 horas de indisponibilidad del sistema de historias clínicas electrónicas. Vector confirmado: phishing mediante adjunto malicioso en email a personal administrativo.			
Cronología del incidente			
Fase	Fecha inicio	Hora inicio	Observaciones
Identificación	02/10/2025	11:15	Usuario del sistema reporta ERROR 500 en acceso a historiales. Confirmación ransomware.
Contención	02/10/2025	11:25	Aislamiento físico HCE-SRV01, bloqueo VLAN Clínica, se deshabilitan VPNs.
Mitigación	02/10/2025	12:00	Eliminación malware, análisis forense.
Recuperación	02/10/2025	13:00	Restauración desde backup, validación integridad datos y puesta en producción de forma gradual y segura.
Cierre	02/10/2025	16:00	Sistemas operativos al 100%, verificación sin riesgos residuales.
Impacto del incidente en la empresa			
Área afectada	Observaciones		
Servicios asistenciales	Cancelación de 35 consultas, 12 pacientes urgentes atendidos sin acceso a su historial, retraso considerable en resultados de laboratorio		
Datos personales	9.2 TB de historiales médicos cifrados (76% del total). Notificación a AEPD por brecha datos de salud (RGPD art. 33)		

Operativa interna	<i>20 profesionales sin acceso al sistema durante 5 horas aprox. Facturación paralizada</i>
Impacto reputacional	<i>7 quejas de pacientes, 1 solicitud y relleno de hoja de reclamaciones al servicio de protección al paciente, 2 menciones negativas en redes sociales.</i>
Medidas adoptadas	
Acciones correctivas	<i>Restauración completa desde backup, Cambio masivo de credenciales, Actualización inmediata de reglas firewall, Eliminación persistencia</i>
Acciones preventivas	<i>Implementación de MFA para accesos al sistema, Reducir la periodicidad de los backups.</i>
Lecciones aprendidas	<i>MTTD de 45 minutos inaceptable para servicios críticos, Concienciación insuficiente del personal en phishing, Segmentación básica que permitió una propagación lateral demasiado rápida, Backup diario insuficiente.</i>
Propuestas de mejora	<i>Evaluar contratación de SOC, Simulaciones de incidentes periódicas, Curso concienciación phishing obligatorio para todo el personal, Reconfiguración de EDR</i>

Tabla 17. Informe post-incidente

3.3.6. Incidentes de apoyo para la validación del sistema

Con el objetivo de evaluar el sistema propuesto ante varios tipos de incidentes realizamos una evaluación -simplificada- de otros dos tipos de incidentes. Esto permitirá la posterior comparación entre incidentes de distinta naturaleza y criticidad evaluando la flexibilidad del modelo.

Para no extender el contenido de este TFG de forma innecesaria y evitar la redundancia no se rellenarán las plantillas de los anexos, únicamente se mostrará la información relevante asociada a cada uno de los ataques.

1. Campaña de phishing dirigida a empleados.

El 5 de octubre de 2025, se detecta una campaña de phishing dirigida de forma específica al personal administrativo de *PearTrees Medical Services*.

Hora	Situación
9:15	Un primer empleado reporta al departamento IT de la empresa un email sospechoso el cual hace referencia en el asunto a un supuesto cambio de horario laboral y solicitando un <i>login</i> al sistema para ver el nuevo cuadrante.
9:30	El personal de seguridad identifica a 15 empleados que recibieron el mismo correo.
9:45	Se realiza un análisis de los correos y se observa que enlaza a un dominio fraudulento que simula el de la empresa.
10:00	Bloqueo del dominio en <i>firewall</i> y filtro de correo
10:15	Comunicación a todos los empleados para que eliminen el correo de forma inmediata.
10:30	Se verifica que 2 empleados accedieron al enlace fraudulento sin que ninguno, afortunadamente, llegara a introducir sus credenciales.

Tabla 18. Cronología del incidente 2

Una vez analizadas las evidencias del ataque se determina que se trata de un ataque *spear phishing* con información real asociada a la empresa cuyo objetivo es el robo de las credenciales de acceso a los sistemas.

El dominio se comprueba que fue creado con 48 horas de antelación en un servidor ubicado en Rusia y que el certificado SSL es fraudulento.

Los datos relevantes de la gestión del incidente son:

- Detección: Usuarios y filtro de correo.
- Clasificación: Criticidad Media, al no implicar un impacto operativo inmediato y únicamente representar un riesgo potencial para las credenciales.
- Contención: Bloqueo del dominio fraudulento, actualización de las reglas del *firewall*, cambio preventivo contraseñas a usuarios de departamentos afectados.
- Erradicación: Eliminación de correos fraudulentos, escaneo de *endpoints*, monitorización del tráfico saliente.
- Recuperación: prácticamente inmediata.
- Propuesta de mejora: Mejorar la formación del personal en identificación de phishing, implementar MFA de forma urgente.

2. Detección de malware en una estación de trabajo de un usuario.

El 8 de octubre de 2025, el sistema EDR alerta sobre comportamiento malicioso en la estación de laboratorio identificada como LAB-03. Esta alerta se produce fuera del horario de trabajo del laboratorio.

Hora	Situación
14:20	El EDR lanza una alerta de un proceso extraño detectado en LAB-03
14:25	El propio EDR aísla de forma automática la estación
14:30	Mediante un análisis remoto se identifica que existe un troyano ejecutándose.
14:45	Se identifica el origen: guardia de seguridad (servicio subcontratado) introduce un USB personal e infectado en la estación

15:00	Escaneo completo de las estaciones del laboratorio, afortunadamente ninguna más se ha visto afectada.
15:30	Limpieza completa LAB-03, reinstalación desde imagen <i>golden</i>
16:00	Restauración datos desde <i>backup</i> , vuelta a producción.

Tabla 19. Cronología del incidente 3

Una vez analizadas las evidencias del ataque se determina que se trata de un ataque cuyo objetivo era el robo de credenciales almacenadas y de datos de las aplicaciones y que el vector de ataque utilizado es un dispositivo USB infectado.

Se determina que se trata de un incidente con una peligrosidad ALTA el cual puede llevar asociado el acceso a datos sensibles.

Los datos relevantes de la gestión del incidente son:

- Detección: automática (EDR).
- Clasificación: Criticidad ALTA (datos sensibles laboratorio)
- Contención: Aislamiento automático.
- Erradicación: Análisis forense y eliminación del *malware*,
- Recuperación: Reinstalación desde imagen limpia.
- Propuesta de mejora: Reforzar la política corporativa relativa a la utilización de USB externos, revisión de los controles acceso físico, concienciación del personal de la empresa y de las subcontratas.

3.4. Indicadores clave

Finalmente, tal y como se ha descrito en el apartado 3.2 de este TFG, se evaluarán una serie de indicadores clave en función de unas métricas que sean de utilidad para cuantificar el tiempo de actividad, el tiempo de inactividad y la rapidez y eficacia con la que los equipos resuelven los incidentes.

Para realizar un estudio estructurado y con el objetivo de obtener unas métricas equivalentes en cada uno de los incidentes se hace uso de las plantillas existentes en el ANEXO E.

3.4.1. MTTD

En primer lugar, analizaremos una métrica que resulta clave para evaluar los sistemas como es el *Mean Time to Detect* (MTTD), como ya se ha descrito en apartados anteriores mide el tiempo promedio entre que ocurre un incidente y el momento en que es detectado por parte del equipo o del sistema. Este dato resulta crucial para evaluar la eficacia de la monitorización y la rapidez de respuesta ante problemas, ya que un MTDD bajo indica una mejor capacidad de identificación y resolución de incidentes, minimizando el impacto y las pérdidas.

- **INCIDENTE 1: Ransomware:**

Hora de inicio del incidente: 10:30
Hora de detección: 11:15

$$MTTD = 11:15 - 10:30 = 45 \text{ minutos}$$

- **INCIDENTE 2: Phishing:**

Hora de inicio del incidente: 9:15
Hora de detección: 9:30

$$MTTD = 9:30 - 9:15 = 15 \text{ minutos}$$

- **INCIDENTE 3: Malware:**

Hora de inicio del incidente: 14:20
Hora de detección: 14:20

$$MTTD = 14:20 - 14:20 = 0 \text{ minutos}$$

3.4.2. MTTR

En segundo lugar, examinaremos otra métrica que resulta fundamental para la evaluación de la eficacia operativa: *el Mean Time to Respond (MTTR)*. Como se ha indicado en secciones precedentes de este mismo TFG, se trata de un indicador que cuantifica el tiempo promedio transcurrido desde la detección de un incidente hasta su completa resolución y la restauración de la normalidad operativa. Este parámetro resulta esencial para valorar la capacidad de respuesta organizativa y la efectividad de los procedimientos de mitigación, ya que un MTTR reducido refleja una gestión ágil y coordinada que limita la exposición al riesgo y acelera la recuperación del servicio. La optimización de este indicador está relacionada directamente con la minimización del impacto económico, operacional y reputacional derivado de las interrupciones de seguridad.

- **INCIDENTE 1: Ransomware:**

Hora de detección: 11:15
Hora de recuperación: 16:00

$$MTTR = 16:00 - 11:15 = 4 \text{ horas y } 45 \text{ minutos}$$

- **INCIDENTE 2: Phishing:**

Hora de detección: 9:30
Hora de recuperación: 10:45

$$MTTR = 10:45 - 9:30 = 1 \text{ hora y } 15 \text{ minutos}$$

- **INCIDENTE 3: Malware:**

Hora de detección: 14:20

Hora de recuperación: 16:00

$$MTTR = 16:00 - 14:20 = \mathbf{1 \text{ hora y } 40 \text{ minutos}}$$

3.4.3. Tasa de falsos positivos

Además del cálculo de su capacidad de detección, los sistemas de monitorización se deben evaluar en función de la precisión de sus alertas. Una tasa de falsos positivos elevada genera fatiga en los equipos, costes operativos ocultos y, algo muy peligroso, el riesgo de que alertas genuinas sean ignoradas.

Para el cálculo de la tasa de falsos positivos – ya que no disponemos de datos reales en el caso práctico simulado- nos basaremos una serie de investigaciones recientes de profesionales del sector [27]. Por tanto, asumimos que las tasas de falsos positivos se encuentran en un rango entre el 50% y el 90% [28].

Para el análisis que se ha llevado a cabo en este TFG con el objetivo de mostrar un escenario realista y que sea representativo de una organización mediana, se han tomado valores intermedios dentro del rango:

- Tasa de falsos positivos: alrededor del 75%.
- Tiempo medio de investigación por falsa alarma: 25 minutos.

Tasa de falsos positivos				
Incidente	Alertas diarias	Tasa de FP	Falsos positivos	Tiempo empleado
Ransomware	28	70%	20	8,3 horas
Phishing	42	75%	32	13,3 horas
Malware USB	18	70%	13	5,4 horas
Total	88	73,9%*	65	27 horas

Tabla 20. Tasa de falsos positivos.

* Mediana

3.5. Análisis de resultados

El análisis de resultados se lleva a cabo en base a los resultados previamente obtenidos durante la simulación de los incidentes propuestos y que han sido desarrollados anteriormente. Con este objetivo se han evaluado una serie de indicadores clave previamente definidos (MTTD, MTTR y tasa de falsos positivos),

para evaluar la eficacia del procedimiento de gestión de incidentes aplicado en la empresa *PearTrees Medical Services*.

- **MTTD (*Mean Time to Detect*)**

En primer lugar, de los datos del indicador MTTD, extraemos las siguientes conclusiones:

Encontramos un caso muy problemático (*Ransomware* 45 minutos), y se pone de manifiesto la principal deficiencia encontrada en el sistema. Este ataque tarda 45 minutos en ser detectado formalmente, dependiendo casi exclusivamente de reportes humanos. Esto está muy por encima de umbrales aceptables, evidenciando una de las debilidades evidentes del sistema.

Por otra parte, existe un caso en el que los tiempos de detección han sido óptimos (*Malware*, tiempo despreciable), demostrando que, si las herramientas de detección especializadas tienen una configuración óptima para un vector de ataque concreto, la detección automática del incidente puede llegar a ser prácticamente inmediata.

Por tanto, en función de los parámetros detectados en la simulación del caso práctico, podemos determinar que:

- La detección ha sido reactiva y muy desigual, demostrando inconsistencia.
- En algunos casos, depende excesivamente de la vigilancia humana.
- Se pone de manifiesto la importancia de un sistema de monitorización que sea proactivo, integrado y que esté afinado para todas las amenazas.

- **MTTR (*Mean Time to Respond*)**

El incidente principal evaluado en este TFG *-ransomware-* conlleva una compleja técnica muy superior al resto, por tanto, su tiempo de resolución se ha visto incrementado en comparación con los otros dos incidentes. No obstante, gracias a la existencia de copias de seguridad válidas y a la existencia de un procedimiento operativo, permitió recuperar la operatividad sin recurrir al pago del rescate.

En cambio, en los otros dos ejemplos propuestos, sus tiempos de respuesta han resultado considerablemente más ágiles. Esto indica que los procedimientos funcionan de forma más eficiente cuando el impacto es limitado y los sistemas afectados no forman parte del núcleo asistencial de la organización.

- **Tasa de falsos positivos**

Durante la simulación realizada se ha observado que *-especialmente en los incidentes relacionados con phishing y malware-* el volumen de alertas generadas incluye un alto porcentaje de eventos que no derivan en incidentes reales y, por tanto, se trata de falsos positivos.

Esta situación concuerda con lo que se ha observado en entornos corporativos reales, en los cuales las herramientas de detección priorizan la sensibilidad frente a la precisión.

De los resultados extraídos en la simulación podemos destacar que, en el caso del incidente de *ransomware*, la tasa de falsos positivos fue sensiblemente menor, ya que las alertas generadas estaban directamente asociadas a comportamientos que resultan claramente anómalos.

No obstante, el análisis global evidencia la necesidad de mejorar el afinado de las reglas de detección y los mecanismos de correlación de eventos, con el objetivo de reducir el ruido y optimizar la capacidad de respuesta ante incidentes críticos.

Finalmente, contrastamos los resultados obtenidos durante la simulación del caso práctico con los umbrales previamente definidos en el análisis de impacto en el negocio (BIA) que fue previamente desarrollado en el apartado 2.8.3 de este TFG.

El incidente de *ransomware*, afectó directamente al sistema de historias clínicas electrónicas, el cual fue identificado en el BIA como un servicio crítico con un MTPD de una hora. Durante la simulación, la interrupción del servicio superó dicho umbral, lo que confirma el elevado impacto previsto en el análisis de impacto en el negocio – que se realizó previamente- y valida la clasificación del incidente como de criticidad alta.

Por otra parte – siguiendo con el incidente de *ransomware*- los objetivos de recuperación que fueron definidos en el BIA (RTO y RPO) sí pudieron cumplirse gracias a la disponibilidad de copias de seguridad válidas.

En cambio, en el segundo incidente -relacionado con la campaña de *Phishing*- el impacto sobre los servicios críticos definidos en el BIA fue limitado. El incidente se mantuvo en todo momento dentro de los márgenes aceptables de tolerancia predefinidos, ya que, en ningún caso, se superaron los umbrales de indisponibilidad definidos para los servicios críticos. Este resultado pone de manifiesto la importancia de la concienciación del personal y de los mecanismos de detección temprana en la reducción del impacto de este tipo de amenazas.

En el último de los incidentes del caso práctico, - el que corresponde con una infección de *malware* en un equipo- no tuvo, en ningún caso, una afectación directa sobre los servicios esenciales y su impacto fue reducido. La detección se produjo de forma inmediata, lo que supuso su contención sin llegar a producirse una propagación lateral ni una afectación a ninguno de los sistemas críticos.

Por tanto, una vez realizada esta comparativa, se constata que los mayores riesgos para la organización – como era de suponer- están concentrados en los incidentes que afectan directamente a sus sistemas críticos, especialmente cuando la detección se dilata en el tiempo. Mientras que los incidentes de menor impacto se gestionan dentro de los márgenes aceptables, el caso de *ransomware* pone de manifiesto la

necesidad de reforzar los mecanismos de detección temprana para garantizar el cumplimiento de los objetivos de continuidad del negocio.

4. Conclusiones y trabajos futuros

4.1. Conclusiones

El objetivo principal que fue marcado al inicio de este Trabajo Final de Grado fue el diseño de un sistema de gestión de incidentes de seguridad informática que fuera adaptable a entornos corporativos, y que se alinee con los principales estándares y marcos normativos de referencia. Por tanto, durante el desarrollo del mismo, se ha puesto de manifiesto que el objetivo se ha conseguido de forma satisfactoria.

En la simulación ha quedado demostrado que el modelo, basado en las seis fases descritas y respaldado por una serie de documentación de apoyo previamente definida, ha demostrado ser plenamente aplicable y eficaz. Por otra parte, el sistema es estructurado, escalable y adaptable a distintos entornos corporativos.

Por tanto, el sistema propuesto ha servido para abordar la gestión de incidentes de forma estructurada, completando cada una de las fases del ciclo de vida del incidente, definiendo claramente los roles implicados y las responsabilidades y, gracias a una serie de procedimientos, ha servido para mejorar la coordinación interna de la empresa y reducir los tiempos de respuesta ante incidentes de seguridad informática.

En cuanto a los resultados de la simulación, se sitúan dentro de los valores coherentes en consonancia con los objetivos planteados.

A continuación, se amplía la tabla desarrollada en el apartado 1.2.2 de esta memoria, en la cual se señalaban los objetivos parciales al inicio de este trabajo, añadiendo una serie de campos en función de los objetivos alcanzados:

Objetivo parcial	Tarea asociada	Alcanzado	Justificación
Investigación de las amenazas	Documentar las principales amenazas en el contexto actual.	Sí	Se ha realizado de forma satisfactoria un análisis detallado de las principales amenazas en el capítulo 2 de esta memoria.
Análisis preliminar	Revisión de normativa y recopilación de buenas prácticas.	Sí	En los apartados 2.1 y 2.2 de esta memoria se ha llevado a cabo una revisión profunda de los estándares y normas de referencia y tanto nacional como internacional
Diseño metodológico	Evaluar el ciclo de vida de incidentes y definir roles.	Sí	Se ha definido un ciclo de vida completo del incidente y se han establecido roles y responsabilidades claras, alineadas con estándares internacionales, descritos en los apartados 2.6 y 2.7.

Elaboración de documentación	RACI, matrices de criticidad, diagramas de flujo, informes, etc.	Sí	En cuanto a la documentación, se han desarrollado matrices RACI, matrices de criticidad y plantillas de informes, las cuales han sido definidas en el capítulo 3 y desarrolladas en los anexos, facilitando, en gran medida, la aplicación práctica del modelo.
Simulación práctica	A modo de ejemplo: aplicación del modelo en un caso ficticio.	Sí	El modelo ha sido validado mediante la simulación de varios incidentes en una empresa ficticia, detallados en el apartado 3.3, demostrando su viabilidad operativa ante diversos escenarios.
Medición de indicadores	Evaluación con KPIs: MTTR, MTTD y tasa de falsos positivos	Sí	Con el objetivo de evaluar la eficacia del sistema propuesto, se han calculado y analizado indicadores clave de rendimiento (MTTD, MTTR y tasa de falsos positivos) en el apartado 3.4 de esta memoria.

Tabla 21. Objetivos parciales conseguidos.

La tabla anterior muestra el grado de consecución de cada uno de los objetivos parciales definidos al inicio del Trabajo de Fin de Grado, junto con la referencia a la evidencia correspondiente en la memoria. Este análisis permite comprobar la coherencia entre los objetivos planteados, el trabajo realizado y los resultados obtenidos.

La planificación realizada al inicio del trabajo ha sido seguida y, a grandes rasgos, el trabajo realizado se ha ajustado al cronograma previsto.

No obstante, durante el desarrollo del trabajo ha sido necesario introducir una serie de pequeños ajustes, principalmente relacionados con la ampliación del análisis de amenazas y la documentación de apoyo. Estos cambios no han alterado la estructura general del proyecto definida al inicio, y han servido, por tanto, para reforzar la coherencia del trabajo y, sobre todo, para mejorar su aplicabilidad en la parte práctica.

4.2. Líneas de trabajo futuras y propuestas de mejora

A pesar de haber conseguido los resultados esperados, el trabajo realizado ha abierto una serie de líneas de investigación y/o de mejora que no se han desarrollado en profundidad.

En primer lugar, para reforzar el componente humano, queda pendiente desarrollar un modelo para aplicar programas de formación y concienciación asociados al sistema propuesto en este TFG.

Por otra parte, este modelo podría evaluarse, con pequeñas adaptaciones, a sectores específicos, como, por ejemplo, infraestructuras críticas, sector bancario, energético etc.

Finalmente, otra posible línea futura y que sobrepasa el alcance inicial de este proyecto, es la integración del sistema con herramientas como pueden ser: SIEM, SOAR, EDR, las cuales nos permitirían avanzar en la automatización en la detección de incidentes, mejorando, en gran medida, la respuesta.

5. Glosario

A continuación, se incluye una recopilación de los principales términos, acrónimos y conceptos técnicos empleados a lo largo de la presente memoria. A modo de referencia se ha utilizado el glosario de términos de ciberseguridad de INCIBE [30] y el Diccionario de la lengua española [31].

A

Adware [2.5.4]

Software malicioso que muestra publicidad no deseada. En algunos casos se considera malware.

Análisis BIA (Business Impact Analysis) [2.8.3, 3.1, 3.5]

Análisis que identifica las actividades críticas de una organización y determina los tiempos máximos de interrupción tolerables.

Ataque DDoS [2.5.3]

Ataque distribuido de denegación de servicio que satura un servidor con tráfico para hacerlo inaccesible.

Ataque por diccionario [2.5.1]

Ataque que utiliza listas de contraseñas comunes para intentar acceder a un sistema.

Ataque de fuerza bruta [2.5.1]

Ataque que prueba todas las combinaciones posibles para adivinar una contraseña.

B

Backdoor [2.5.4]

Acceso oculto a un sistema que elude los controles de seguridad normales.

Baiting [2.5.2]

Técnica de ingeniería social la cual utiliza un cebo físico o digital para engañar a la víctima.

Botnet [2.5.4]

Red de dispositivos infectados y controlados de forma remota con el objetivo de realizar ataques.

Business Email Compromise (BEC) [2.5.3]

Estafa dirigida a empresas que implica la suplantación de identidad por correo electrónico para, finalmente, realizar transferencias fraudulentas.

C

Ciberamenaza [1.1, 2.5]

Evento o acción potencial que puede llegar a comprometer la seguridad de los sistemas de información.

Ciberataque [1.1, 2.5, 3.3]

Ataque deliberado contra sistemas, redes o datos informáticos.

Cibercrimen [1.1]

Actividad delictiva que utiliza o tiene como objetivo sistemas y redes informáticas.

Ciberseguridad [1.1, 2.1, 4.1]

Conjunto de prácticas, tecnologías y procesos para proteger sistemas, redes y datos de ataques digitales.

Ciclo de vida del incidente [2.6, 3.1]

Fases por las que pasa un incidente de seguridad, en este contexto y según INCIBE: Preparación, Identificación, Contención, Mitigación, Recuperación y Post-Incidente.

CISO (Chief Information Security Officer) [2.7.1]

Director de Seguridad de la Información, responsable máximo de la estrategia y gestión de la ciberseguridad en la organización.

Confidencialidad [2.4, 2.8.1, 3.3.5]

Garantía de que la información solo es accesible para aquellos que han sido previamente autorizados.

Contención [2.6.3, 3.3]

Fase del ciclo de vida del incidente cuyo objetivo es limitar la propagación y el impacto del incidente.

Continuidad del negocio [1.2.1, 2.3, 3.1, 4.1]

Capacidad de una organización para mantener sus operaciones esenciales.

CSIRT (Computer Security Incident Response Team) [2.2, 3.3.4]

Equipo especializado en la respuesta y gestión de incidentes de seguridad informática.

D**Delegado de Protección de Datos (DPO)** [2.1, 3.3.4]

Responsable de supervisar el cumplimiento del RGPD/GDPR en una organización. Están definidas sus atribuciones en la LOPDGDD (artículos 37,38 y 39)

Disponibilidad [2.2, 2.8.1, 3.3.5]

Garantía de que los sistemas y datos son accesibles cuando son necesarios.

DNS Spoofing [2.5.3]

Ataque que altera los registros DNS con el objetivo de redirigir el tráfico a servidores maliciosos.

Dumpster Diving [2.5.2]

Técnica de ingeniería social que consiste en buscar información confidencial en la basura física.

E**EDR (Endpoint Detection and Response)** [1.2.2, 2.8.2, 3.2.6, 4.2]

Solución de seguridad que monitorea y responde a amenazas en los dispositivos finales.

Email Spoofing [2.5.3]

Suplantación de la dirección del remitente en un correo electrónico.

ENISA (European Union Agency for Cybersecurity) [2.5]

Agencia de la Unión Europea para la Ciberseguridad.

Esquema Nacional de Seguridad (ENS) [2.1]

Marco normativo español que establece la política de seguridad de la información para el sector público (RD 311/2022).

Escaneo de puertos [2.5.3]

Técnica utilizada con el objetivo de descubrir puertos abiertos en un sistema que se encuentra conectado a la red.

F**Falso positivo [3.4.3, 4.1]**

Alerta generada por un sistema de seguridad que identifica erróneamente una actividad normal como maliciosa.

Firewall [1.1.2, 2.8.2]

Dispositivo o software que controla el tráfico de red entre redes con distintos niveles de confianza.

Fuga de información [2.2, 3.3.5]

Acceso, divulgación o pérdida no autorizada de información confidencial.

G**GDPR / RGPD (General Data Protection Regulation) [1.3.2, 2.1, 3.3.4]**

Reglamento General de Protección de Datos de la Unión Europea.

Gestión de incidentes [1.1, 2.6, 3.1, 4.1]

Proceso coordinado para manejar la respuesta a incidentes de seguridad informática.

Gobernanza de la ciberseguridad [2.7, 4.1]

Marco de políticas, procedimientos y estructuras útiles para dirigir y controlar la ciberseguridad en una organización.

Gusano [2.5.4]

Tipo de malware diseñado para autorreplicarse y propagarse a través de redes sin necesidad de intervención del usuario.

H**Hash criptográfico [2.4]**

Función matemática que genera identificadores alfanuméricos y convierte datos de cualquier tamaño en una cadena de longitud fija, utilizada para verificar la integridad de los datos.

I**Identificación del incidente [2.6.2, 3.3.2]**

Fase del ciclo de vida en la que se detecta y confirma un incidente de seguridad.

Impacto del incidente [2.6.1, 3.3.3]

Consecuencias que un incidente de seguridad tiene sobre las operaciones, activos o reputación de una organización.

Indicadores clave de rendimiento (KPI) [3.4, 4.1]

Métricas utilizadas para evaluar el desempeño de un proceso o sistema, como el MTTD o MTTR en la gestión de incidentes.

Ingeniería social [2.5.2, 3.3.6]

Conjunto de técnicas que los delincuentes usan para engañar a los usuarios de

sistemas/servicios TIC para que les faciliten datos, manipulación psicológica de personas para que realicen acciones o divulguen información confidencial.

Inyección SQL [2.5.3]

Ataque que inserta código SQL malicioso en una consulta de base de datos para manipularla o acceder a los datos.

Integridad [2.4, 2.8.1, 3.3.5]

Garantía de que la información no ha sido alterada de una forma no autorizada.

IP Spoofing [2.5.3]

Suplantación de una dirección IP para ocultar la identidad del atacante o suplantar a otro dispositivo.

ISO/IEC 27001 [2.1]

Estándar internacional para Sistemas de Gestión de la Seguridad de la Información (SGSI).

ISO/IEC 27002 [2.1]

Código de buenas prácticas para controles de seguridad de la información.

ISO/IEC 27003 [2.1]

Guía para la implementación de un SGSI según ISO/IEC 27001.

ISO/IEC 27004 [2.1]

Estándar para la medición de la eficacia de un SGSI.

ISO/IEC 27005 [2.1]

Estándar para la gestión del riesgo de seguridad de la información.

ISO/IEC 27035 [2.1, 2.6, 3.1]

Estándar internacional para la gestión de incidentes de seguridad de la información.

ISO/IEC 27701 [2.1]

Extensión de ISO/IEC 27001 para la gestión de la privacidad (PIMS).

K

Keylogger [2.5.4]

Software o hardware que monitoriza y registra las pulsaciones del teclado sin el conocimiento del usuario.

M

Malware [2.5.4, 3.3.6]

Término genérico para referirnos a software malicioso (virus, troyanos, ransomware, etc.).

Man in the Middle [2.5.3]

Ataque en el que el atacante intercepta la comunicación entre dos partes sin que estas lo sepan. En algunos casos la información se modifica mediante la inyección de paquetes con algún fin malicioso.

Matriz de criticidad [3.2, 4.1]

Herramienta utilizada para clasificar incidentes en función de su nivel de peligrosidad e impacto.

Matriz RACI [3.2, 4.1]

Matriz que define los roles (Responsable, Aprobador, Consultado, Informado) para cada tarea en un proceso.

Mitigación [2.6.3, 3.3.4]

Fase del ciclo de vida del incidente dedicada a eliminar la causa raíz del mismo y restaurar los sistemas a un estado seguro.

MTPD (Maximum Tolerable Period of Disruption) [2.8.3, 3.5]

Tiempo máximo que una actividad crítica puede estar interrumpida sin que el daño para la organización sea irreversible.

MTTD (Mean Time to Detect) [3.4.1, 4.1]

Tiempo medio transcurrido desde que se produce un incidente hasta que este es detectado.

MTTR (Mean Time to Respond/Recover) [3.4.2, 4.]

Tiempo medio necesario para resolver un incidente completamente, desde su detección hasta su completa resolución.

N**NIST SP 800-61** [2.1, 2.6, 3.1]

Publicación especial del NIST que proporciona recomendaciones para la respuesta a incidentes de ciberseguridad.

P**Phishing** [2.5.2, 3.3.6]

Ataque de ingeniería social que alguien suplanta a una entidad o servicio utilizando correos electrónicos fraudulentos para robar información sensible.

Plan de respuesta ante incidentes [2.6, 3.1]

Documento que describe los procedimientos y responsabilidades para manejar incidentes de seguridad.

Post-incidente [2.6.6, 3.3.5]

Fase final del ciclo de vida del incidente dedicada al análisis, lecciones aprendidas y mejora continua.

Preparación [2.6.1, 3.1]

Fase del ciclo de vida del incidente en la que la organización establece recursos y capacidades para responder eficazmente.

R**Ransomware** [2.5.4, 3.3.2]

Tipo de malware que cifra los datos de la víctima y exige un rescate para restaurarlos.

Recuperación [2.6.5, 3.3.4]

Fase del ciclo de vida del incidente cuyo objetivo es restablecer los sistemas y servicios afectados a la normalidad operativa.

Registro de incidentes [3.3.2, 4.1]

Documento formal que recoge la información básica de un incidente desde su detección inicial.

Resiliencia digital [1.3, 4.1]

Capacidad de una organización para anticiparse, resistir, adaptarse y recuperarse de perturbaciones relacionadas con la ciberseguridad.

RPO (Recovery Point Objective) [2.8.3]

Cantidad máxima de pérdida de datos (medida en tiempo) que una organización puede tolerar tras un incidente.

RTO (Recovery Time Objective) [2.8.3, 3.5]

Tiempo máximo aceptable para recuperar un servicio o proceso tras un incidente.

Rootkit [2.5.4]

Conjunto de herramientas de software malicioso diseñado para obtener acceso privilegiado y ocultar su presencia en un sistema.

S**Shoulder Surfing [2.5.2]**

Técnica de ingeniería social que consiste en observar directamente la pantalla o teclado de una persona para obtener información.

SIEM (Security Information and Event Management) [1.2.2, 4.2]

Solución que recopila, analiza y correlaciona datos de seguridad de diversas fuentes para la detección de amenazas.

Smishing [2.5.2]

Ataque de phishing que utiliza mensajes SMS o aplicaciones de mensajería móvil.

Sniffing [2.5.3]

Técnica de interceptación pasiva del tráfico de red.

SOAR (Security Orchestration, Automation and Response) [1.2.2, 4.2]

Conjunto de tecnologías que permiten orquestar, automatizar y ejecutar respuestas a incidentes de seguridad.

Spear Phishing [2.5.2]

Ataque de phishing altamente dirigido a una persona u organización específica.

Spyware [2.5.4]

Software malicioso diseñado para recopilar información sobre una persona u organización sin su conocimiento.

Sostenibilidad digital [1.3.1, 4.1]

Capacidad de mantener sistemas tecnológicos seguros, fiables y éticos a lo largo del tiempo.

Spoofing [2.5.3]

Suplantación de identidad en la que un atacante se hace pasar por una entidad legítima.

T**Teletrabajo [1.1.2, 2.5.2]**

Modalidad laboral que se realiza fuera de las instalaciones de la empresa, utilizando tecnologías de la información. Se ha generalizado en los últimos años.

Triada CIA [2.4]

Modelo fundamental de seguridad de la información basado en Confidencialidad, Integridad y Disponibilidad.

Troyano [2.5.4]

Tipo de malware que se disfraza de software legítimo con el objetivo de engañar a los usuarios y ejecutar acciones maliciosas.

V

Vishing [2.5.2]

Ataque de phishing que utiliza llamadas telefónicas de voz o sistemas de voz sobre IP (VoIP).

6. Bibliografía

- [1] G. K. Lindemulder, «**¿Qué es la ciberseguridad?**,» IBM, 12 agosto 2024. [En línea]. Available: <https://www.ibm.com/es-es/think/topics/cybersecurity>. [Último acceso: 23 octubre 2025].
- [2] L. Oliveira Sanchez, «**La historia de la ciberseguridad**,» NordVPN, 25 diciembre 2022. [En línea]. Available: https://nordvpn.com/es/blog/historia-ciberseguridad/?srsltid=AfmBOoq_8HssxfYz7ryl8kwhoq8g00jmkIE3O2sAcfZuisM4XowD76u. [Último acceso: 23 octubre 2025].
- [3] INCIBE, «**La ciberseguridad desde los inicios: evolución de la seguridad**,» INCIBE, 29 agosto 2023. [En línea]. Available: <https://www.incibe.es/empresas/blog/la-ciberseguridad-desde-los-inicios-evolucion-de-la-seguridad#>. [Último acceso: 23 octubre 2025].
- [4] INCIBE, «**INCIBE presenta su balance de ciberseguridad 2024 con más de 97.000 incidentes gestionados**,» INCIBE, 20 abril 2025. [En línea]. Available: <https://www.incibe.es/incibe/sala-de-prensa/incibe-presenta-su-balance-de-ciberseguridad-2024-con-mas-de-97000-incidentes>. [Último acceso: 24 octubre 2025].
- [5] E. Protector., «**GDPR: La guía más exhaustiva para cumplir con la normativa**,» (s.f). [En línea]. Available: <https://www.endpointprotector.es/epp/gdpr-the-most-in-depth-guide-to-stay-compliant>. [Último acceso: 25 octubre 2025].
- [6] Secureframe, «**Serie ISO 27000: Qué son las normas y cuál es su propósito**,» Secureframe, 2023 abril 27. [En línea]. Available: <https://secureframe.com/es-es/blog/iso-27000>. [Último acceso: 31 octubre 2025].
- [7] National Institute of Standards and Technology, «**Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile**,» U.S. Department of Commerce, abril 2025. [En línea]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r3.pdf>. [Último acceso: 31 octubre 2025].
- [8] Unón Europea, «**Síntesis del Reglamento General de Protección de Datos (RGPD)**,» Publicaciones de la Oficina de la Unión Europea., 27 abril 2016. [En línea]. Available: europa.eu/ES/legal-content/summary/general-data-protection-regulation-gdpr.html. [Último acceso: 3 noviembre 2025].
- [9] Estado, España. Jefatura del, «**Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad**,» 3 mayo 2022. [En línea]. Available: <https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191>. [Último acceso: 3 noviembre 2025].
- [10] INCIBE, «**Ciberamenazas contra entornos empresariales**,» [En línea]. Available:

- https://www.incibe.es/sites/default/files/contenidos/guias/doc/ciberamenazas_contra_entornos_empresariales.pdf. [Último acceso: 9 noviembre 2025].
- [11] INCIBE, «**Ciberseguridad en la identidad digital y la reputación online**,» [En línea]. Available: https://www.incibe.es/sites/default/files/contenidos/guias/doc/GU%C3%8DA_CIBERSEGURIDAD_EN_LA_IDENTIDAD_DIGITAL.pdf. [Último acceso: 10 noviembre 2025].
- [12] INCIBE, «**Como gestionar una fuga de información**,» [En línea]. Available: https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_ciberseguridad_gestion_fuga_informacion_0.pdf. [Último acceso: 10 noviembre 2025].
- [13] INCIBE, «**Guía de Gestión de Crisis (INCIBE)**,» [En línea]. Available: https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_gestion_de_crisis.pdf. [Último acceso: 10 noviembre 2025].
- [14] INCIBE, «**Guía Nacional de Notificación y Gestión de Ciberincidentes**,» 21 febrero 2020. [En línea]. Available: https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_nacional_notificacion_gestion_ciberincidentes.pdf. [Último acceso: 12 noviembre 2025].
- [15] INCIBE, «**Procedimiento de gestión de ciberincidentes para el sector privado y la ciudadanía**,» [En línea]. Available: [incibe-cert_gestion_ciberincidentes_sector_privado.pdf](https://www.incibe.es/sites/default/files/contenidos/guias/doc/incibe-cert_gestion_ciberincidentes_sector_privado.pdf). [Último acceso: 12 noviembre 2025].
- [16] INCIBE OSI, «**Guía de ciberataques**,» [En línea]. [Último acceso: 12 noviembre 2025].
- [17] J. Von Neumann, **The Theory of Self-Reproducing Automata**, University of Illinois Press, 1966.
- [18] welivesecurity by eset, «**En retrospectiva: el virus Pakistani Brain**,» ESET, 25 enero 2017. [En línea]. Available: <https://www.welivesecurity.com/la-es/2017/01/25/retrospectiva-pakistani-brain/>. [Último acceso: 11 noviembre 2025].
- [19] ESET, «**Morris: el primer gusano para computadoras de la historia**,» ESET, 18 noviembre 2017. [En línea]. Available: <https://www.eset.com/latam/blog/cultura-y-seguridad-digital/gusano-morris-un-experimento-costoso/>. [Último acceso: 12 noviembre 2025].
- [20] CAIDA, «**CAIDA Analysis of Code-Red**,» 30 julio 2020. [En línea]. Available: <https://www.caida.org/archive/code-red/>. [Último acceso: 12 noviembre 2025].
- [21] Telefónica Cybersecurity & Cloud Tech, S.L.U., «**Informe sobre el estado de la seguridad 2025 H1**,» Telefónica Tech, 2025. [En línea]. Available: <https://telefonicatech.com/actualidad/informe-estado-de-la-seguridad-2025-h1>. [Último acceso: 2025 noviembre 2025].
- [22] Fortinet, «**¿Qué es la tríada CIA?**,» Fortinet, [En línea]. Available: <https://www.fortinet.com/lat/resources/cyberglossary/cia-triad>. [Último acceso: 13 noviembre 2025].
- [23] H. P. E. (HPE), «**¿Qué es una amenaza de ciberseguridad?**,» Hewlett Packard Enterprise (HPE) España, 2025. [En línea]. Available:

<https://www.hpe.com/es/es/what-is/cybersecurity-threats.html>. [Último acceso: 2025 octubre 26].

- [24] Agencia de la Unión Europea para la Ciberseguridad (ENISA), «**ENISA Threat Landscape 2025**,» ENISA, Bruselas, 2025.
- [25] INCIBE, «**Roles en ciberseguridad: desde el CEO a los usuarios finales**,» INCIBE, 20 junio 2023. [En línea]. Available: <https://www.incibe.es/empresas/blog/roles-en-ciberseguridad-desde-el-ceo-los-usuarios-finales>. [Último acceso: 15 noviembre 2025].
- [26] «**¿Qué es el estándar HL7- FHIR para el sector salud?**,» Siftia, [En línea]. Available: <https://siftia.tech/es/recursos/recoleccion-datos/que-es-el-estandar-hl7-fhir-para-el-sector-salud-2/>. [Último acceso: 1 diciembre 2025].
- [27] INCIBE, «**Guía Nacional de notificación y gestión de ciberincidentes**,» 2021. [En línea]. Available: https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_nacional_notificacion_gestion_ciberincidentes.pdf. [Último acceso: 5 diciembre 2025].
- [28] Secuarden, «**Secuarden's Canonical Secure Development Brief – Issue #4**,» Secuarden, 14 septiembre 2025. [En línea]. Available: <https://kb.secuarden.com/briefs/issue-4-why-security-alerts-ignored>. [Último acceso: 15 diciembre 2025].
- [29] E. Gately, «**Channel Futures**,» Channel Futures, 15 diciembre 2023. [En línea]. Available: <https://www.channelfutures.com/backup/critical-start-false-positives-plague-cybersecurity-professionals>. [Último acceso: 10 diciembre 2025].
- [30] INCIBE, «**Glosario de ciberseguridad. Instituto Nacional de Ciberseguridad.**,» 2025. [En línea]. Available: https://www.incibe.es/sites/default/files/contenidos/guias/doc/guia_glosario_ciberseguridad_2021.pdf. [Último acceso: 26 diciembre 2025].
- [31] Real Academia Española, «**Diccionario de la lengua española**,» RAE, [En línea]. Available: <https://dle.rae.es/>. [Último acceso: 2025 diciembre 2025].

7. Anexos

Anexo A: Registro y gestión de incidentes.

REGISTRO Y GESTIÓN DE INCIDENTES DE CIBERSEGURIDAD				
Organización:				
Creador del documento:	Nombre:			
	Apellidos:			
	Cargo:			
Versión del documento:				
Id:	Fecha de detección:		Hora de detección:	
Estado del incidente:	Abierto		Tipo de incidente:	
	En curso			
	Cerrado			
Descripción inicial:				
Vector de ataque:				
Activos potencialmente comprometidos:				

Nivel de criticidad estimado:
Plan de acción y contramedidas:
Responsable asignado:
Observaciones:

Anexo B: Clasificación y criticidad de incidentes.

DOCUMENTO DE CLASIFICACIÓN Y CRITICIDAD DE INCIDENTES							
Id:				Tipo de incidente:			
Nivel de peligrosidad del incidente:							
Bajo	Incidentes fácilmente gestionables						
Medio	Incidentes que afectan a servicios no críticos						
Alto	Incidentes que comprometen sistemas críticos						
Muy alto	Incidentes que afectan a $\geq 75\%$ de los sistemas						
Crítico	Incidentes que afectan a $\geq 90\%$ de los sistemas						
Niveles de impacto del ciberincidente:							
Sin impacto	No existe ningún impacto apreciable.						
Bajo	Interrupción de la prestación de un servicio.						
Medio	Interrupción en la presentación del servicio superior al 5% de usuarios.						
Alto	Interrupción en la prestación del servicio superior a 1 hora y superior al 10% de usuarios.						
Muy alto	Interrupción en la prestación del servicio superior a 8 horas y superior al 35% de los usuarios.						
Crítico	Interrupción en la prestación del servicio superior a 24 horas y superior al 50% de los usuarios.						
Probabilidad de éxito del ataque:							
Baja		Media		Alta		Muy alta	

Anexo C: Roles y responsabilidades (Matriz RACI).

ROL ACTIVIDAD	CEO	CISO	EQUIPO TI	DPD	USUARIOS
Detección del incidente	I	C	R	I	R
Clasificación y evaluación	I	A	R	C	I
Contención	I	A	R	C	I
Mitigación / Erradicación	I	A	R	C	I
Recuperación del servicio	I	A	R	C	I
Comunicación interna y externa	A	R	C	R	I
Informe post-incidente	I	A	R	C	I
Leyenda:					
R: Responsable	A: Accountable	C: Consulted	I: Informed		

Anexo D: Procedimientos operativos de respuesta.

Procedimiento Operativo de respuesta ante incidentes de seguridad informática de la empresa PearTrees Medical Services
1.Introducción
La presente guía tiene como intención definir un procedimiento operativo específico para la gestión de incidentes de ciberseguridad en <i>PearTrees Medical Services</i> , garantizando una respuesta eficaz, coordinada y que esté alineada con los requisitos de seguridad, continuidad asistencial y cumplimiento normativo aplicables a una organización del sector sanitario.
2.Alcance
Este procedimiento es aplicable a todos los sistemas, servicios y usuarios de <i>PearTrees Medical Services</i> , incluyendo: • Infraestructura clínica y administrativa de la empresa. • Sistemas de historias clínicas, el cual goza de especial protección debido a la naturaleza y confidencialidad de los datos. • Sistemas de laboratorio • Servidores de imágenes diagnósticas • Infraestructura VPN y accesos remotos • Personal de las sedes de Palma, Sóller y Manacor
2.1 Roles implicados
Los roles y responsabilidades se asignan conforme a la matriz RACI definida en el Anexo C, destacando: • CISO: Coordinación general del incidente • Equipo TI: Ejecución técnica de las acciones • DPD: Evaluación de impacto en protección de datos • CEO / Dirección: Toma de decisiones estratégicas • Usuarios: Detección y notificación inicial
3.Fases de la respuesta ante incidentes
La gestión de incidentes se estructura en siete fases consecutivas, aunque algunas de ellas pueden solaparse en función de la naturaleza del incidente: 
3.1 Preparación
El objetivo principal en esta fase es el de dotar a la organización de los recursos, procedimientos y de las capacidades necesarias para responder a incidentes previamente a que estos ocurran. A continuación, enumeramos una serie de acciones que, entre otras, resultan esenciales en esta fase: • Definición de roles y responsabilidades entre el personal implicado en la gestión de incidentes. • Se establecerán los canales de comunicación, incluyendo alternativas. • Elaboración de plantillas y procedimientos perfectamente documentados. • Formación y concienciación del personal.

• Implementación de mecanismos de monitorización y registro. Esta fase resulta clave para reducir los tiempos de detección y respuesta ante incidentes futuros.
3.2. Detección e identificación del incidente En esta fase el objetivo es el de detectar un evento anómalo en el mismo momento en el que se produzca y, una vez evaluado, determinar si constituye un incidente de seguridad informática. En esta fase resulta crucial: • Recepción de alertas desde los sistemas de seguridad y/o de las notificaciones de los usuarios. • Comunicación inmediata al CISO • Análisis inicial de la información disponible. • Registro del incidente en el sistema de gestión. • Asignación de un identificador único al incidente. El resultado de esta fase es la confirmación de un incidente real y el inicio formal de su gestión.
3.3 Clasificación y evaluación de la criticidad En la fase de clasificación y evaluación es en la que se determina la peligrosidad que tiene el incidente para los activos de la empresa y establecer el grado de prioridad que requiere su tratamiento. Por tanto, las principales actuaciones son: • Evaluación del impacto que conlleva el incidente sobre la organización, principalmente en los activos críticos: ◦ Servicios asistenciales. ◦ Datos personales sujetos a una especial protección ◦ Operativa interna de la empresa. • Determinación del nivel de urgencia y asignarle una prioridad. • Asignación de un nivel de criticidad utilizando una matriz impacto–urgencia. • Evaluar la necesidad de escalado interno y/o notificación externa. En esta fase resulta crucial priorizar los recursos y definir los tiempos de respuesta adecuados para cada incidente.
3.4 Contención Una vez detectado y analizado resulta de vital importancia limitar el alcance del incidente y evitar su propagación a través de la red corporativa, la acciones a realizar con la máxima celeridad posible son: • Aislamiento de los sistemas que resulten afectados. • Desconexión de equipos comprometidos si fuera posible. • Bloqueo o revocación de las credenciales afectadas o comprometidas. • Activación de medidas temporales para mantener la continuidad asistencial. Estas acciones se deben de llevar a cabo junto con las que se determinen dada la naturaleza del incidente.
3.5 Erradicación En esta fase las acciones se deben encaminar a eliminar la causa raíz del incidente, para esto se llevarán a cabo las siguientes medidas: • Eliminación del malware o el software malicioso detectado. • Corrección de las posibles vulnerabilidades que hayan resultado explotadas. • Aplicación de parches de seguridad y otras medidas. • Revisión de configuraciones de acceso y permisos. Estas acciones se deben de llevar a cabo junto con las que se determinen dada la naturaleza del incidente.

3.6 Recuperación

En esta fase se deben reestablecer los sistemas y servicios que se hayan visto afectados garantizando, en todo momento, que esto se realice de forma segura.

Acciones:

- Restauración de sistemas desde copias de seguridad verificadas.
- Validación de la integridad de la información clínica y de laboratorio.
- Reincorporación progresiva de los sistemas a producción.
- Monitorización reforzada tras la recuperación.

Estas acciones se deben de llevar a cabo junto con las que se determinen dada la naturaleza del incidente.

3.7 Análisis post-incidente y mejora continua

Una vez se recupera el normal funcionamiento de los sistemas, resulta conveniente evaluar cómo se ha realizado la gestión del incidente y que medidas se deben tomar para realizar las mejoras necesarias al sistema para que un incidente similar no vuelva a ocurrir.

Acciones:

- Elaboración del informe post-incidente.
- Cálculo de indicadores clave:
 - MTTD
 - MTTR
 - Tasa de falsos positivos
- Identificación de lecciones aprendidas.
- Propuesta de medidas de mejora técnica y organizativa.

Comunicación y cumplimiento de la normativa vigente

En caso de que el incidente implique datos personales de pacientes:

- El DPD evaluará la necesidad de notificación a la autoridad competente.
- Se garantizará el cumplimiento del GDPR.
- La comunicación externa será coordinada por Dirección y el DPD.

Anexo E: Plantillas de informes y KPIs.

Informe post-incidente			
Id:		Tipo de incidente:	
Fecha de detección:			
Fecha de resolución:		Nivel de criticidad	
Resumen del incidente:			
Cronología del incidente			
Fase	Fecha inicio	Hora inicio	Observaciones
Identificación			
Contención			
Mitigación			
Recuperación			
Cierre			
Impacto del incidente en la empresa			
Área afectada	Observaciones		
Servicios asistenciales			
Datos personales			
Operativa interna			

Impacto reputacional	
Medidas adoptadas	
Acciones correctivas	
Acciones preventivas	
Lecciones aprendidas	
Propuestas de mejora	

Cálculo de indicadores		
Mean Time to Detect (MTTD)		
Hora de inicio (A):	Hora de detección (B):	
MTTD= B-A	MTTD:	
Mean Time to Respond (MTTR)		
Hora de detección (A):	Hora de recuperación (B):	
MTTR= B-A	MTTR:	
Tasa de falsos positivos		
Número total de alertas:	Alertas reales:	Falsos positivos:
$Tasa\ FP = \frac{Falsos\ positivos}{Alertas\ totales} \cdot 100$		Tasa de falsos positivos: